ETSI TR 103 305-1 V3.1.1 (2018-09)



CYBER;
Critical Security Controls for Effective Cyber Defence;
Part 1: The Critical Security Controls

Reference
RTR/CYBER-0034-1

Keywords
cyber security, cyber-defence, information assurance

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - NAF 742 C
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° 7803/88

Important notice

The present document can be downloaded from:
http://www.etsi.org/standards-search

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the only prevailing document is the print of the Portable Document Format (PDF) version kept on a specific network drive within ETSI Secretariat.

Users of the present document should be aware that the document may be subject to revision or change of status.
Information on the current status of this and other ETSI documents is available at
https://portal.etsi.org/TB/ETSIDeliverableStatus.aspx

If you find errors in the present document, please send your comment to one of the following services:
https://portal.etsi.org/People/CommiteeSupportStaff.aspx

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI.
The content of the PDF version shall not be modified without the written authorization of ETSI.
The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI 2018.
All rights reserved.

DECT™, **PLUGTESTS**™, **UMTS**™ and the ETSI logo are trademarks of ETSI registered for the benefit of its Members.
3GPP™ and **LTE**™ are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners.
oneM2M logo is protected for the benefit of its Members.
GSM® and the GSM logo are trademarks registered and owned by the GSM Association.

Contents

Intellectual Property Rights 4
Foreword 4
Modal verbs terminology 4
Executive summary 4
Introduction 5
1 Scope 6
2 References 6
2.1 Normative references 6
2.2 Informative references 6
3 Definitions and abbreviations 7
3.1 Definitions 7
3.2 Abbreviations 7
4 Critical Security Controls 8
4.0 Structure of the Critical Security Controls Document 8
4.1 CSC 1: Inventory and Control of Hardware Assets 9
4.2 CSC 2: Inventory and Control of Software Assets 11
4.3 CSC 3: Continuous Vulnerability Management 13
4.4 CSC 4: Controlled Use of Administrative Privileges 15
4.5 CSC 5: Secure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers 17
4.6 CSC 6: Maintenance, Monitoring, and Analysis of Audit Logs 19
4.7 CSC 7: Email and Web Browser Protections 21
4.8 CSC 8: Malware Defences 23
4.9 CSC 9: Limitation and Control of Network Ports, Protocols, and Services 25
4.10 CSC 10: Data Recovery Capabilities 26
4.11 CSC 11: Secure Configurations for Network Devices such as Firewalls, Routers, and Switches 28
4.12 CSC 12: Boundary Defence 29
4.13 CSC 13: Data Protection 32
4.14 CSC 14: Controlled Access Based on the Need to Know 33
4.15 CSC 15: Wireless Access Control 36
4.16 CSC 16: Account Monitoring and Control 38
4.17 CSC 17: Implement a Security Awareness and Training Program 40
4.18 CSC 18: Application Software Security 42
4.19 CSC 19: Incident Response and Management 44
4.20 CSC 20: Penetration Tests and Red Team Exercises 46
History 49

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The information pertaining to these essential IPRs, if any, is publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI Web server (https://ipr.etsi.org/).

Pursuant to the ETSI IPR Policy, no investigation, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

Foreword

This Technical Report (TR) has been produced by ETSI Technical Committee Cyber Security (CYBER).

The present document is part 1 of a multi-part deliverable covering the Critical Security Controls for Effective Cyber Defence, as identified below:

Part 1: "The Critical Security Controls";

Part 2: "Measurement and auditing";

Part 3: "Service Sector Implementations";

Part 4: "Facilitation Mechanisms";

Part 5: "Privacy enhancement".

Modal verbs terminology

In the present document "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

The present document captures and describes the prioritized set of actions that collectively form a defence-in-depth set of best practices that mitigate the most common attacks against systems and networks. These actions are specified by ETSI in the present document the Critical Security Controls (CSC) which are developed and maintained by the Center for Internet Security (CIS) as an independent, expert, global non-profit organization. The CIS provides ongoing development, support, adoption, and use of these Critical Security Controls [i.1]. The Controls reflect the combined knowledge of actual attacks and effective defences of experts from every part of the cyber security ecosystem. This ensures that the Controls are an effective and specific set of technical measures available to detect, prevent, respond, and mitigate damage from the most common to the most advanced of those attacks.

The Controls are not limited to blocking the initial compromise of systems, but also address detecting already compromised machines and preventing or disrupting attackers' follow-on actions. The defences identified through these Controls deal with reducing the initial attack surface by hardening device configurations, identifying compromised machines to address long-term threats inside an organization's network, disrupting attackers' command-and-control of implanted malicious code, and establishing an adaptive, continuous defence and response capability that can be maintained and improved. The five critical tenets of an effective cyber defence system as reflected in the Critical Security Controls are:

- Offense informs defence: Use knowledge of actual attacks that have compromised systems to provide the foundation to continually learn from these events to build effective, practical defences. Include only those controls that can be shown to stop known real-world attacks.
- Prioritization: Invest first in Controls that will provide the greatest risk reduction and protection against the most dangerous threat actors, and that can be feasibly implemented in a computing environment.
- Measurements and Metrics: Establish common metrics to provide a shared language for executives, IT specialists, auditors, and security officials to measure the effectiveness of security measures within an organization so that necessary adjustments can be identified and implemented quickly.
- Continuous diagnostics and mitigation: Carry out continuous measurement to test and validate the effectiveness of current security measures, and to help drive the priority of next steps.
- Automation: Automate defences so that organizations can achieve reliable, scalable, and continuous measurements of their adherence to the Controls and related metrics.

Introduction

The evolution of cyber defence is increasingly challenging. Massive data losses, theft of intellectual property, credit card breaches, identity theft, threats to privacy, denial of service - these have become endemic. Access exists to an extraordinary array of security tools and technology, security standards, training and classes, certifications, vulnerability databases, guidance, best practices, catalogues of security controls, and countless security checklists, benchmarks, and recommendations.

But all of this technology, information, and oversight has become a veritable "Fog of More:" competing options, priorities, opinions, and claims that can paralyze or distract an enterprise from vital action. Business complexity is growing, dependencies are expanding, users are becoming more mobile, and the threats are evolving. New technology brings great benefits, but it also means that data and applications are now distributed across multiple locations, many of which are not within the organization's infrastructure. In this complex, interconnected world, no enterprise can think of its security as a standalone problem.

Focus is needed to establish priority of action, collective support, and keeping knowledge and technology current in the face of rapidly evolving problems and an apparently infinite number of possible solutions. The most critical areas need to be addressed and the first steps taken toward maturing risk management programs. This includes a roadmap of fundamentals, and guidance to measure and improve the implementation defensive steps that have the greatest value. These issues led to, and drive, the Critical Security Controls. The value is determined by knowledge and data - the ability to prevent, alert, and respond to the attacks that are plaguing enterprises today.

Initiating Implementation

Some of the Critical Security Controls, in particular CSC 1 through CSC 6, are essential to success and should be considered among the very first things to be done. This is the approach taken by, for example, the DHS Continuous Diagnostic and Mitigation (CDM) Program. A similar approach is recommended by the Australian Signals Directorate (ASD) with their "Essential Eight" - a well-regarded and demonstrably effective set of cyber-defence actions that map very closely into the Critical Security Controls.

This Version of the Critical Security Controls

Feedback on Version 6 of the Controls (October 2015) was used this to drive the evolution of Version 7 to improve clarity and conciseness, as well as change emphasis. The new version enables greater manageable implementation, measurement, and automation.

1 Scope

The present document describes a specific set of technical measures available to detect, prevent, respond, and mitigate damage from the most common to the most advanced of cyber-attacks. The measures reflect the combined knowledge of actual attacks and effective defences.

The present document is technically equivalent and compatible with CIS Controls, Version 7.0 of the Center for Internet Cybersecurity [i.1].

2 References

2.1 Normative references

Normative references are not applicable in the present document.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents are not necessary for the application of the present document but they assist the user with regard to a particular subject area.

[i.1] The Center for Internet Cybersecurity: "CIS Controls™". Version 7.0 2018.

NOTE: Available at https://www.cisecurity.org/critical-controls.cfm.

[i.2] NIST Special Publication 800-57 (Part 1-Revision 4): "Recommendation for Key Management".

[i.3] IEEE 802.1X™ (2010): "Port Based Network Access Control".

[i.4] ETSI TR 103 305-2: "CYBER; Critical Security Controls for Effective Cyber Defence; Part 2: Measurement and auditing".

[i.5] NIST Special Publication 800-63: "Digital Identity Guidelines".

[i.6] NIST Special Publication 800-50: "Building an Information Technology Security Awareness and Training Program".

[i.7] ENISA: "The new users' guide: How to raise information security awareness".

NOTE: Available at https://www.enisa.europa.eu/publications/archive/copy_of_new-users-guide.

[i.8] EDUCAUSE: "Cybersecurity Awareness Resource Library".

NOTE: Available at https://spaces.internet2.edu/display/2014infosecurityguide/Cybersecurity+Awareness+Resource+Library.

[i.9] SANS: "Security Awareness Reports & Resources".

NOTE: Available at https://www.sans.org/security-awareness-training/reports.

[i.10] ETSI TR 103 331: "CYBER; Structured threat information sharing".

[i.11] CREST: "Cyber Security Incident Response Guide".

NOTE: Available at https://www.crest-approved.org/wp-content/uploads/2014/11/CSIR-Procurement-Guide.pdf.

[i.12] CREST: "Guidance and standards on cyber defence topics".

NOTE: Available at https://www.crest-approved.org/wp-content/uploads/2014/11/CSIR-Procurement-Guide.pdf.

[i.13] PCI Security Standards Council.

NOTE: Available at https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf.

[i.14] OWASP Penetration Testing Methodologies.

NOTE: Available at https://www.owasp.org/index.php/Penetration_testing_methodologies.

3 Definitions and abbreviations

3.1 Definitions

For the purposes of the present document, the following terms and definitions apply:

Critical Security Control (CSC): specified capabilities that reflect the combined knowledge of actual attacks and effective defences of experts that are maintained by the Center for Internet Security

NOTE: Available at https://www.cisecurity.org/critical-controls.cfm.

quick win: actions that can be relatively easily taken with minimal resources that have a significant cyber security benefit

3.2 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACK	ACKnowledge
ACL	Access Controls List
AES	Advanced Encryption Standard
ASD	Australian Signals Directorate
ASLR	Address Space Layout Randomization
BYOD	Bring Your Own Device
CCE™	Common Configuration Enumeration
CDM	Continuous Diagnostic and Mitigation
CIS	Center for Internet Security
CPE™	Common Platform Enumeration
CSAF	Common Security Advisory Framework (Technical Committee OASIS)
CSC	Critical Security Control or Capability
CVE®	Common Vulnerability Enumeration
CVRF	Common Vulnerability Reporting Framework
CVSS	Common Vulnerability Scoring System
DEP	Data Execution Prevention
DHCP	Dynamic Host Configuration Protocol
DHS	Department of Homeland Security
DLP	Data Loss Prevention
DMZ	DeMilitarized Zone
DNS	Domain Name System
EAP	Extensible Authentication Protocol
HSM	Hardware Security Modules
HTTP	Hypertext Transfer Protocol
ICMP	Internet Control Message Protocol
ID	IDentifier
IDS	Intrusion Detection System
IP	Internet Protocol
IPS	Intrusion Prevention System
IT	Information Technology

LAN	Local Area Network
MAC	Media Access Control
NAC	Network Access Control
NFC	Near-Field Communication
NIST	National Institute of Standards and Technology
OVAL®	Open Vulnerability and Assessment Language
OWASP	Open Web Application Security Project
PCI	Payment Card Industry
SANS	SysAdmin, Audit, Network, Security institute
SCADA	Supervisory Control and Data Acquisition
SCAP	Security Content Automation Program
SIEM	Security Information Event Management or Security Incident Event Management
SP	Special Publication
SPF	Sender Policy Framework
SQL	Structured Query Language
SYN	SYNchronize
TCP	Transmission Control Protocol
TLS	Transport Layer Security
UDP	User Datagram Protocol
URL	Uniform Resource Locator
USB	Universal Serial Bus
VLAN	Virtual Local Area Network
VPN	Virtual Private Network
WAF	Web Application Firewall
WIDS	Wireless Intrusion Detection System
WLAN	Wireless Local Area Network
XCCDF	eXtensible Configuration Checklist Description Format

NOTE: CPE®, CVE™, OVAL® and CCE™ are trademarks of The MITRE Corporation operating as a non-profit Federally Funded Research and Development Center (FFRDC) of the U.S. Department of Homeland Security. See http://stixproject.github.io/legal/. Both CVE® and OVAL® are registered service marks. This information is given for the convenience of users of the present document and does not constitute an endorsement by ETSI of the product named. Equivalent products may be used if they can be shown to lead to the same results.

4 Critical Security Controls

4.0 Structure of the Critical Security Controls Document

The Critical Security Controls in the present document are organized as shown in figure 4-0. Controls 1 through 6 are essential to success and should be considered among the very first things to be done.

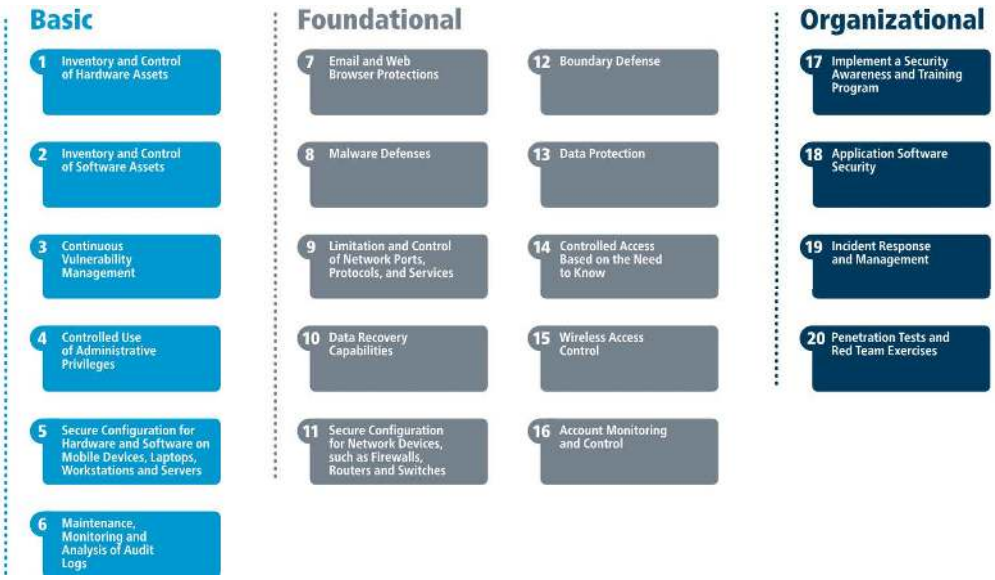


Figure 4-0: Organization of the Critical Security Controls

As depicted in figure 4-0, Controls 17-20 are different in character than Controls 1-16. While they have many technical elements, these are less focused on technical as controls and more focused on people and processes. They are pervasive in that they should be considered across the entire enterprise, and across all of Controls 1-16. Their measurements and metrics of success are driven more by observations about process steps and outcomes, and less by technical data gathering. They are also complex topics in their own right, each with an existing body of literature and guidance. For Controls 17-20, a small number of elements are identified that are critical to an effective program in each area. Processes and resources are described which can be used to develop a more comprehensive enterprise treatment of each topic. Both commercial and non-profit resources are identified. The ideas, requirements, and processes expressed in the references are well supported by the marketplace.

Each Control includes:

- A description of the importance of the Control (Why is This Control Critical) in blocking or identifying presence of attacks and an explanation of how attackers actively exploit the absence of this control.
- A table of the specific actions ("sub-controls") that organizations should take to implement, automate, and measure effectiveness of the control.
- Procedures and Tools that enable implementation and automation.
- Sample Entity Relationship Diagrams that show components of implementation.

In addition to the present document, ETSI TR 103 305-2 [i.4], can be referenced for implementing each control.

4.1 CSC 1: Inventory and Control of Hardware Assets

Actively manage (inventory, track, and correct) all hardware devices on the network so that only authorized devices are given access, and unauthorized and unmanaged devices are found and prevented from gaining access.

Why Is This Control Critical?

Attackers, who can be located anywhere in the world, are continuously scanning the address space of target organizations, waiting for new and possibly unprotected systems to be attached to the network. They are particularly interested in devices which come and go off of the enterprise's network such as laptops or Bring-Your-Own-Devices (BYOD) which might be out of synch with security updates or might already be compromised. Attacks can take advantage of new hardware that is installed on the network one evening but not configured and patched with appropriate security updates until the following day. Even devices that are not visible from the Internet can be used by attackers who have already gained internal access and are hunting for internal pivot points or victims. Additional systems that connect to the enterprise's network (e.g. demonstration systems, temporary test systems, guest networks) should also be managed carefully and/or isolated in order to prevent adversarial access from affecting the security of enterprise operations.

Large, complex enterprises understandably struggle with the challenge of managing intricate, fast-changing environments. But attackers have shown the ability, patience, and willingness to "inventory and control" our assets at very large scale in order to support their opportunities.

Managed control of all devices also plays a critical role in planning and executing system backup, incident response, and recovery .

Table 4-1: CSC 1 - Inventory and Control of Hardware Assets

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
1.1	Devices	Identify	Utilize an Active Discovery Tool	Utilize an active discovery tool to identify devices connected to the organization's network and update the hardware asset inventory.
1.2	Devices	Identify	Use a Passive Asset Discovery Tool	Utilize a passive discovery tool to identify devices connected to the organization's network and automatically update the organization's hardware asset inventory.
1.3	Devices	Identify	Use DHCP Logging to Update Asset Inventory	Use Dynamic Host Configuration Protocol (DHCP) logging on all DHCP servers or IP address management tools to update the organization's hardware asset inventory.
1.4	Devices	Identify	Maintain Detailed Asset Inventory	Maintain an accurate and up-to-date inventory of all technology assets with the potential to store or process information. This inventory should include all hardware assets, whether connected to the organization's network or not.
1.5	Devices	Identify	Maintain Asset Inventory Information	Ensure that the hardware asset inventory records the network address, hardware address, machine name, data asset owner, and department for each asset and whether the hardware asset has been approved to connect to the network.
1.6	Devices	Respond	Address Unauthorized Assets	Ensure that unauthorized assets are either removed from the network, quarantined or the inventory is updated in a timely manner.
1.7	Devices	Protect	Deploy Port Level Access Control	Utilize port level access control, following 802.1x standards, to control which devices can authenticate to the network. The authentication system should be tied into the hardware asset inventory data to ensure only authorized devices can connect to the network.
1.8	Devices	Protect	Utilize Client Certificates to Authenticate Hardware Assets	Use client certificates to authenticate hardware assets connecting to the organization's trusted network.

CSC 1: Procedures and Tools

This Control includes both technical and procedural actions, united in a process that accounts for and manages the inventory of hardware and all associated information throughout its life cycle. It links to business governance by establishing information/asset owners who are responsible for each component of a business process that includes information, software, and hardware. Organizations can use large-scale, comprehensive enterprise products to maintain IT asset inventories. Others use more modest tools to gather the data by sweeping the network, and manage the results separately in a database.

Maintaining a current and accurate view of IT assets is an ongoing and dynamic process. Organizations can actively scan on a regular basis, sending a variety of different packet types to identify devices connected to the network. Before such scanning can take place, organizations should verify that they have adequate bandwidth for such periodic scans by consulting load history and capacities for their networks. In conducting inventory scans, scanning tools could send traditional ping packets (e.g. ICMP Echo Request) looking for ping responses to identify a system at a given IP address. Because some systems block inbound ping packets, in addition to traditional pings, scanners can also identify devices on the network using transmission control protocol (TCP) synchronize (SYN) or acknowledge (ACK) packets. Once they have identified IP addresses of devices on the network, some scanners provide robust fingerprinting features to determine the operating system type of the discovered machine.

In addition to active scanning tools that sweep the network, other asset identification tools passively listen on network interfaces for devices to announce their presence by sending traffic. Such passive tools can be connected to switch span ports at critical places in the network to view all data flowing through such switches, maximizing the chance of identifying systems communicating through those switches.

Many organizations also pull information from network assets such as switches and routers regarding the machines connected to the network. Using securely authenticated and encrypted network management protocols, tools can retrieve MAC addresses and other information from network devices that can be reconciled with the organization's asset inventory of servers, workstations, laptops, and other devices. Once MAC addresses are confirmed, switches should implement 802.1x and NAC to only allow authorized systems that are properly configured to connect to the network [i.3].

Wireless devices (and wired laptops) may periodically join a network and then disappear, making the inventory of currently available systems very dynamic. Likewise, virtual machines can be difficult to track in asset inventories when they are shut down or paused. Additionally, remote machines accessing the network using virtual private network (VPN) technology may appear on the network for a time, and then be disconnected from it. Whether physical or virtual, each machine using an IP address should be included in an organization's asset inventory.

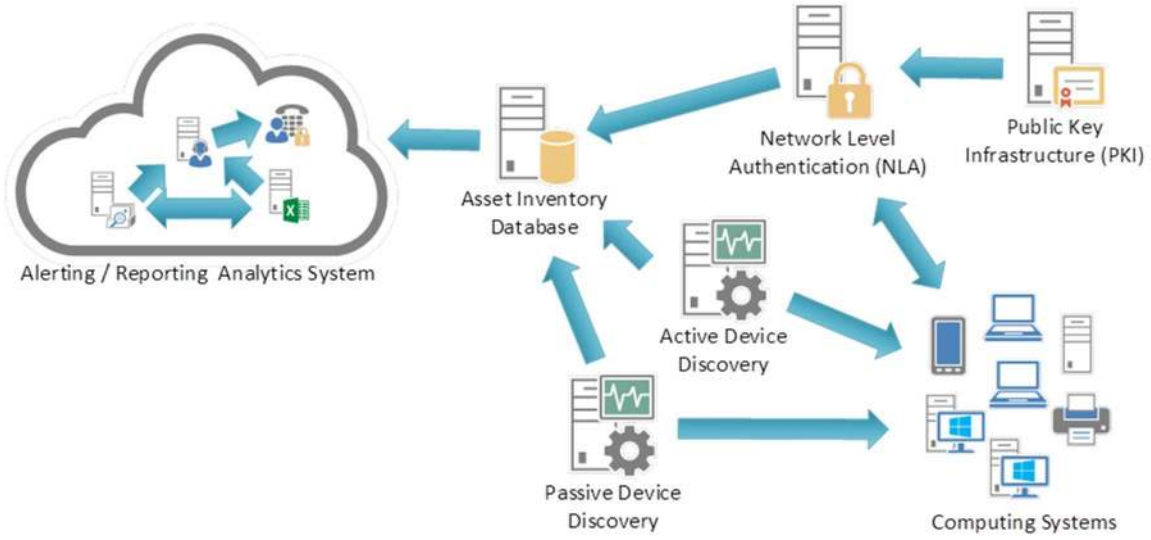


Figure 4-1: CSC 1 System Entity Relationship Diagram

4.2 CSC 2: Inventory and Control of Software Assets

Actively manage (inventory, track, and correct) all software on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

Why Is This Control Critical?

Attackers continuously scan target organizations looking for vulnerable versions of software that can be remotely exploited. Some attackers also distribute hostile web pages, document files, media files, and other content via their own web pages or otherwise trustworthy third-party sites. When unsuspecting victims access this content with a vulnerable browser or other client-side program, attackers compromise their machines, often installing backdoor programs and bots that give the attacker long-term control of the system. Some sophisticated attackers may use zero-day exploits, which take advantage of previously unknown vulnerabilities for which no patch has yet been released by the software vendor. Without proper knowledge or control of the software deployed in an organization, defenders cannot properly secure their assets.

Poorly controlled machines are more likely to be either running software that is unneeded for business purposes (introducing potential security flaws), or running malware introduced by an attacker after a system is compromised. Once a single machine has been exploited, attackers often use it as a staging point for collecting sensitive information from the compromised system and from other systems connected to it. In addition, compromised machines are used as a launching point for movement throughout the network and partnering networks. In this way, attackers may quickly turn one compromised machine into many. Organizations that do not have complete software inventories are unable to find systems running vulnerable or malicious software to mitigate problems or root out attackers.

Managed control of all software also plays a critical role in planning and executing system backup, incident response and recovery.

Table 4-2: CSC 2 - Inventory and Control of Software Assets

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
2.1	Applications	Identify	Maintain Inventory of Authorized Software	Maintain an up-to-date list of all authorized software that is necessary in the enterprise for any business purpose on any business system.
2.2	Applications	Identify	Ensure Software is Supported by Vendor	Ensure that only software applications or operating systems currently supported by the software's vendor are added to the organization's authorized software inventory. Unsupported software should be tagged as unsupported in the inventory system.
2.3	Applications	Identify	Utilize Software Inventory Tools	Utilize software inventory tools throughout the organization to automate the documentation of all software on business systems.
2.4	Applications	Identify	Track Software Inventory Information	The software inventory system should track the name, version, publisher, and install date for all software, including operating systems authorized by the organization.
2.5	Applications	Identify	Integrate Software and Hardware Asset Inventories	The software inventory system should be tied into the hardware asset inventory so all devices and associated software are tracked from a single location.
2.6	Applications	Respond	Address Unapproved Software	Ensure that unauthorized software is either removed or the inventory is updated in a timely manner.
2.7	Applications	Protect	Utilize Application Whitelisting	Utilize application whitelisting technology on all assets to ensure that only authorized software executes and all unauthorized software is blocked from executing on assets.
2.8	Applications	Protect	Implement Application Whitelisting of Libraries	The organization's application whitelisting software should ensure that only authorized software libraries (such as *.dll, *.ocx, *.so, etc.) are allowed to load into a system process.
2.9	Applications	Protect	Implement Application Whitelisting of Scripts	The organization's application whitelisting software should ensure that only authorized, digitally signed scripts (such as *.ps1, *.py, macros, etc.) are allowed to run on a system.
2.10	Applications	Protect	Physically or Logically Segregate High Risk Applications	Physically or logically segregated systems should be used to isolate and run software that is necessary for business operations but incur higher risk for the organization.

CSC 2: Procedures and Tools

Whitelisting can be implemented using a combination of commercial whitelisting tools, policies or application execution tools that come with anti-virus suites and popular operating systems. Commercial software and asset inventory tools are widely available and in use in many enterprises today. The best of these tools provide an inventory check of hundreds of common applications used in enterprises, pulling information about the patch level of each installed program to ensure that it is the latest version and leveraging standardized application names, such as those found in the common platform enumeration specification.

Features that implement whitelists are included in many modern endpoint security suites. Moreover, commercial solutions are increasingly bundling together anti-virus, anti-spyware, personal firewall, and host-based intrusion detection systems (IDS) and intrusion prevention systems (IPS), along with application white and black listing. In particular, most endpoint security solutions can look at the name, file system location, and/or cryptographic hash of a given executable to determine whether the application should be allowed to run on the protected machine. The most effective of these tools offer custom whitelists based on executable path, hash, or regular expression matching. Some even include a gray list function that allows administrators to define rules for execution of specific programs only by certain users and at certain times of day.

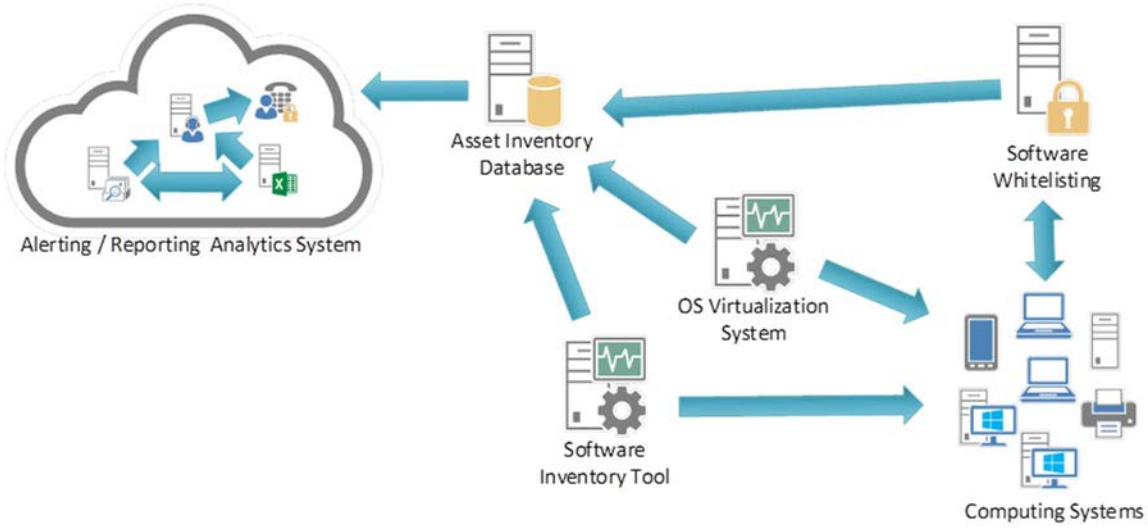


Figure 4-2: CSC 2 System Entity Relationship Diagram

4.3 CSC 3: Continuous Vulnerability Management

Continuously acquire, assess, and take action on new information in order to identify vulnerabilities, remediate, and minimize the window of opportunity for attackers.

Why Is This Control Critical?

Cyber defenders need to operate in a constant stream of new information: software updates, patches, security advisories, threat bulletins, etc. Understanding and managing vulnerabilities has become a continuous activity, requiring significant time, attention, and resources.

Attackers have access to the same information and can take advantage of gaps between the appearance of new knowledge and remediation. For example, when researchers report new vulnerabilities, a race starts among all parties, including: attackers (to "weaponize", deploy an attack, exploit); vendors (to develop, deploy patches or signatures and updates), and defenders (to assess risk, regression-test patches, install).

Organizations that do not scan for vulnerabilities and proactively address discovered flaws face a significant likelihood of having their computer systems compromised. Defenders face particular challenges in scaling remediation across an entire enterprise, and prioritizing actions with conflicting priorities, and sometimes-uncertain side effects.

Table 4-3: CSC 3 - Continuous Vulnerability Management

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
3.1	Applications	Detect	Run Automated Vulnerability Scanning Tools	Utilize an up-to-date SCAP-compliant vulnerability scanning tool to automatically scan all systems on the network on a weekly or more frequent basis to identify all potential vulnerabilities on the organization's systems.
3.2	Applications	Detect	Perform Authenticated Vulnerability Scanning	Perform authenticated vulnerability scanning with agents running locally on each system or with remote scanners that are configured with elevated rights on the system being tested.
3.3	Users	Protect	Protect Dedicated Assessment Accounts	Use a dedicated account for authenticated vulnerability scans, which should not be used for any other administrative activities and should be tied to specific machines at specific IP addresses.
3.4	Applications	Protect	Deploy Automated Operating System Patch Management Tools	Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.
3.5	Applications	Protect	Deploy Automated Software Patch Management Tools	Deploy automated software update tools in order to ensure that third-party software on all systems is running the most recent security updates provided by the software vendor.
3.6	Applications	Respond	Compare Back-to-back Vulnerability Scans	Regularly compare the results from back-to-back vulnerability scans to verify that vulnerabilities have been remediated in a timely manner.
3.7	Applications	Respond	Utilize a Risk-rating Process	Utilize a risk-rating process to prioritize the remediation of discovered vulnerabilities.

CSC 3: Procedures and Tools

A large number of vulnerability scanning tools are available to evaluate the security configuration of systems. Some enterprises have also found commercial services using remotely managed scanning appliances to be effective. To help standardize the definitions of discovered vulnerabilities in multiple departments of an organization or even across organizations, it is preferable to use vulnerability scanning tools that measure security flaws and map them to vulnerabilities and issues categorized using one or more of the following industry-recognized vulnerability, configuration, and platform classification schemes and languages: CVE®, CCE™, OVAL®, CPE™, CVSS and/or XCCDF.

Advanced vulnerability scanning tools can be configured with user credentials to log in to scanned systems and perform more comprehensive scans than what can be achieved without login credentials. The frequency of scanning activities, however, should increase as the diversity of an organization's systems increases to account for the varying patch cycles of each vendor.

In addition to the scanning tools that check for vulnerabilities and misconfigurations across the network, various free and commercial tools can evaluate security settings and configurations of local machines on which they are installed. Such tools can provide fine-grained insight into unauthorized changes in configuration or the inadvertent introduction of security weaknesses by administrators.

Effective organizations link their vulnerability scanners with problem-ticketing systems that automatically monitor and report progress on fixing problems, and that make unmitigated critical vulnerabilities visible to higher levels of management to ensure the problems are solved.

The most effective vulnerability scanning tools compare the results of the current scan with previous scans to determine how the vulnerabilities in the environment have changed over time. Security personnel use these features to conduct vulnerability trending from month to month.

As vulnerabilities related to unpatched systems are discovered by scanning tools, security personnel should determine and document the amount of time that elapses between the public release of a patch for the system and the occurrence of the vulnerability scan. If this time window exceeds the organization's benchmarks for deployment of the given patch's criticality level, security personnel should note the delay and determine if a deviation was formally documented for the system and its patch. If not, the security team should work with management to improve the patching process.

Additionally, some automated patching tools may not detect or install certain patches due to an error by the vendor or administrator. Because of this, all patch checks should reconcile system patches with a list of patches each vendor has announced on its website.

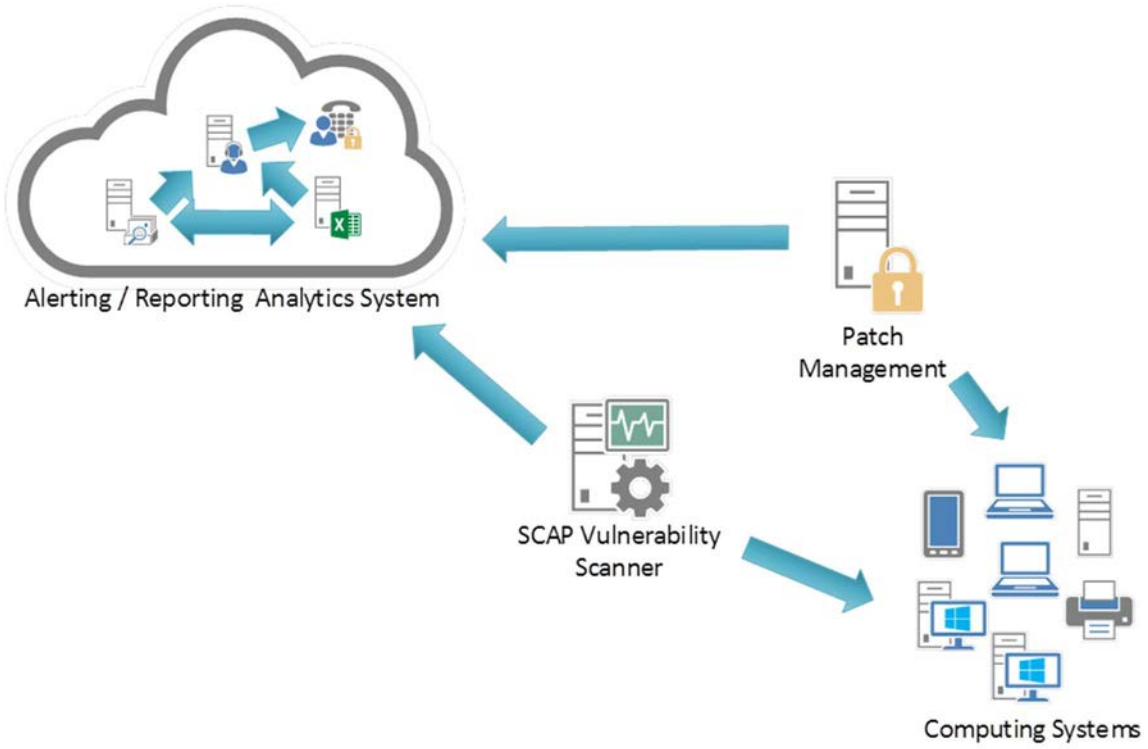


Figure 4-3: CSC 3 System Entity Relationship Diagram

4.4 CSC 4: Controlled Use of Administrative Privileges

The processes and tools used to track/control/prevent/correct the use, assignment, and configuration of administrative privileges on computers, networks, and applications.

Why Is This Control Critical?

The misuse of administrative privileges is a primary method for attackers to spread inside a target enterprise. Two very common attacker techniques take advantage of uncontrolled administrative privileges. In the first, a workstation user running as a privileged user, is fooled into opening a malicious email attachment, downloading and opening a file from a malicious website, or simply surfing to a website hosting attacker content that can automatically exploit browsers. The file or exploit contains executable code that runs on the victim's machine either automatically or by tricking the user into executing the attacker's content. If the victim user's account has administrative privileges, the attacker can take over the victim's machine completely and install keystroke loggers, sniffers, and remote control software to find administrative passwords and other sensitive data. Similar attacks occur with email. An administrator inadvertently opens an email that contains an infected attachment and this is used to obtain a pivot point within the network that is used to attack other systems.

The second common technique used by attackers is elevation of privileges by guessing or cracking a password for an administrative user to gain access to a target machine. If administrative privileges are loosely and widely distributed, or identical to passwords used on less critical systems, the attacker has a much easier time gaining full control of systems, because there are many more accounts that can act as avenues for the attacker to compromise administrative privileges.

Table 4-4: CSC 4 - Controlled Use of Administrative Privileges

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
4.1	Users	Detect	Maintain Inventory of Administrative Accounts	Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.
4.2	Users	Protect	Change Default Passwords	Before deploying any new asset, change all default passwords to have values consistent with administrative level accounts
4.3	Users	Protect	Ensure the Use of Dedicated Administrative Accounts	Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.
4.4	Users	Protect	Use Unique Passwords	Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.
4.5	Users	Protect	Use Multifactor Authentication For All Administrative Access	Use multi-factor authentication and encrypted channels for all administrative account access.
4.6	Users	Protect	Use Dedicated Workstations For All Administrative	Ensure administrators use a dedicated machine for all administrative tasks or tasks requiring administrative access. This machine will be segmented from the organization's primary network and not be allowed internet access. This machine will not be used for reading email, composing documents, or browsing the internet.
4.7	Users	Protect	Limit Access to Scripting Tools	Limit access to scripting tools (such as Microsoft PowerShell and Python) to only administrative or development users with the need to access those capabilities.
4.8	Users	Detect	Log and Alert on Changes to Administrative Group Membership	Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.
4.9	Users	Detect	Log and Alert on Unsuccessful Administrative Account Login	Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.

NOTE: Powershell and Python are the names of products supplied by a variety of parties. Some versions are proprietary, others are free/open-source software. Windows® is a registered trademark of Microsoft Corporation. This information is given for the convenience of users of the present document and does not constitute an endorsement by ETSI of the product named. Equivalent products may be used if they can be shown to lead to the same results.

CSC 4: Procedures and Tools

Built-in operating system features can extract lists of accounts with super-user privileges, both locally on individual systems and on overall domain controllers. To verify that users with high-privileged accounts do not use such accounts for day-to-day web surfing and email reading, security personnel should periodically gather a list of running processes to determine whether any browsers or email readers are running with high privileges. Such information gathering can be scripted, with short shell scripts searching for a dozen or more different browsers, email readers, and document editing programs running with high privileges on machines. Some legitimate system administration activity may require the execution of such programs over the short term, but long-term or frequent use of such programs with administrative privileges could indicate that an administrator is not adhering to this control.

To enforce the requirement for strong passwords, built-in operating system features for minimum password length can be configured to prevent users from choosing short passwords. To enforce password complexity (requiring passwords to be a string of pseudo-random characters), built-in operating system settings or third-party password complexity enforcement tools can be applied.

Password strength and management (e.g. frequency of change) should be considered in a system and life-cycle context. See: "Digital Identity Guidelines" [i.5].

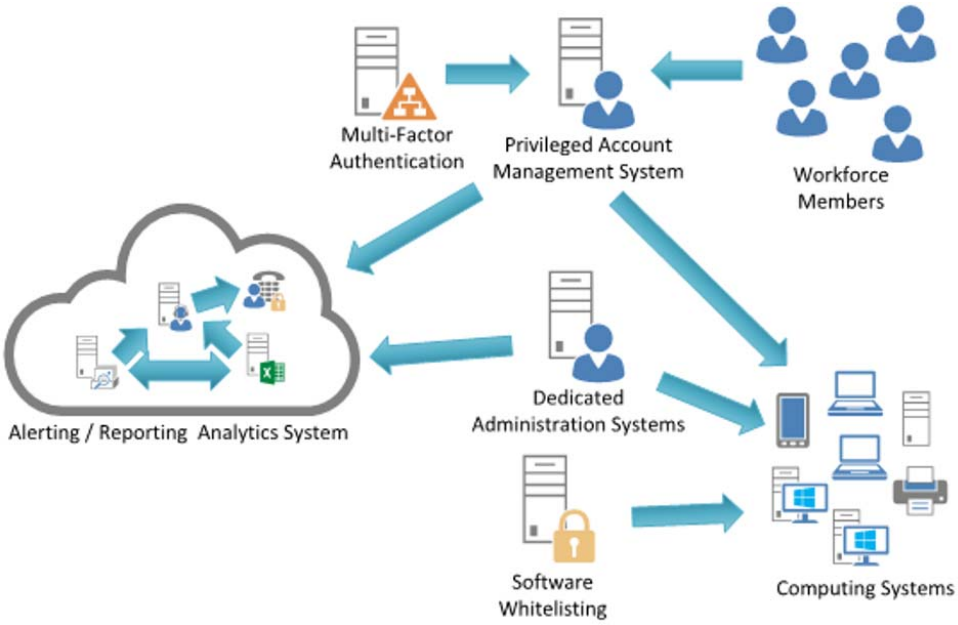


Figure 4-4: CSC 4 System Entity Relationship Diagram

4.5 CSC 5: Secure Configurations for Hardware and Software on Mobile Devices, Laptops, Workstations, and Servers

Establish, implement, and actively manage (track, report on, correct) the security configuration of mobile devices laptops, servers, and workstations using a rigorous configuration management and change control process in order to prevent attackers from exploiting vulnerable services and settings.

Why Is This Control Critical?

As delivered by manufacturers and resellers, the default configurations for operating systems and applications are normally geared towards ease-of-deployment and ease-of-use - not security. Basic controls, open services and ports, default accounts or passwords, older (vulnerable) protocols, pre-installation of unneeded software; all can be exploitable in their default state.

Developing configuration settings with good security properties is a complex task beyond the ability of individual users, requiring analysis of potentially hundreds or thousands of options in order to make good choices (the Procedures and Tool section below provides resources for secure configurations). Even if a strong initial configuration is developed and installed, it should be continually managed to avoid security "decay" as software is updated or patched, new security vulnerabilities are reported, and configurations are "tweaked" to allow the installation of new software or support new operational requirements. If not, attackers will find opportunities to exploit both network-accessible services and client software.

Table 4-5: CSC 5 - Secure Configurations for Hardware and Software

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
5.1	Applications	Protect	Establish Secure Configurations	Maintain documented, standard security configuration standards for all authorized operating systems and software.
5.2	Applications	Protect	Maintain Secure Images	Maintain secure images or templates for all systems in the enterprise based on the organization's approved configuration standards. Any new system deployment or existing system that becomes compromised should be imaged using one of those images or templates.
5.3	Applications	Protect	Securely Store Master Images	Store the master images and templates on securely configured servers, validated with integrity monitoring tools, to ensure that only authorized changes to the images are possible.
5.4	Applications	Protect	Deploy System Configuration Management Tools	Deploy system configuration management tools that will automatically enforce and redeploy configuration settings to systems at regularly scheduled intervals.
5.5	Applications	Detect	Implement Automated Configuration Monitoring Systems	Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.

CSC 5: Procedures and Tools

Rather than start from scratch developing a security baseline for each software system, organizations should start from publicly developed, vetted, and supported security benchmarks, security guides, or checklists. Excellent resources include:

- The CIS Benchmarks™ Program.

NOTE 1: Available at https://www.cisecurity.org/.

- The NIST National Checklist Program.

NOTE 2: https://web.nvd.nist.gov/view/ncp/repository.

Organizations should augment or adjust these baselines to satisfy local policies and requirements, but deviations and rationale should be documented to facilitate later reviews or audits.

For a complex enterprise, the establishment of a single security baseline configuration (for example, a single installation image for all workstations across the entire enterprise) is sometimes not practical or deemed unacceptable. It is likely that one will need to support different standardized images, based on the proper hardening to address risks and needed functionality of the intended deployment (e.g. a web server in the DMZ versus an email or other application server in the internal network). The number of variations should be kept to a minimum in order to better understand and manage the security properties of each, but organizations then should be prepared to manage multiple baselines.

Commercial and/or free configuration management tools can then be employed to measure the settings of operating systems and applications of managed machines to look for deviations from the standard image configurations. Typical configuration management tools use some combination of an agent installed on each managed system, or agentless inspection of systems by remotely logging in to each managed machine using administrator credentials. Additionally, a hybrid approach is sometimes used whereby a remote session is initiated, a temporary or dynamic agent is deployed on the target system for the scan, and then the agent is removed.

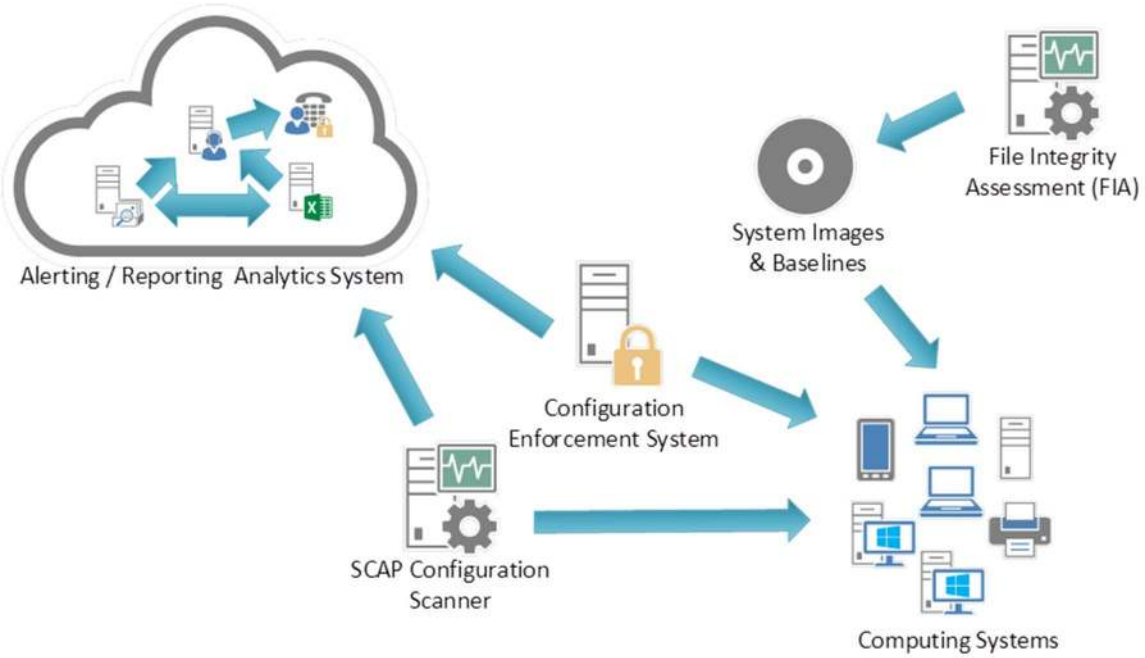


Figure 4-5: CSC 5 System Entity Relationship Diagram

4.6 CSC 6: Maintenance, Monitoring, and Analysis of Audit Logs

Collect, manage, and analyze audit logs of events that could help detect, understand or recover from an attack.

Why Is This Control Critical?

Deficiencies in security logging and analysis allow attackers to hide their location, malicious software, and activities on victim machines. Even if the victims know that their systems have been compromised, without protected and complete logging records they are blind to the details of the attack and to subsequent actions taken by the attackers. Without solid audit logs, an attack may go unnoticed indefinitely and the particular damages done may be irreversible.

Sometimes logging records are the only evidence of a successful attack. Many organizations keep audit records for compliance purposes, but attackers rely on the fact that such organizations rarely look at the audit logs, and they do not know that their systems have been compromised. Because of poor or non-existent log analysis processes, attackers sometimes control victim machines for months or years without anyone in the target organization knowing, even though the evidence of the attack has been recorded in unexamined log files.

Table 4-6: CSC 6 - Maintenance, Monitoring, and Analysis of Audit Logs

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
6.1	Network	Detect	Utilize Three Synchronized Time Sources	Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.
6.2	Network	Detect	Activate Audit Logging	Ensure that local logging has been enabled on all systems and networking devices.
6.3	Network	Detect	Enable Detailed Logging	Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.
6.4	Network	Detect	Ensure Adequate Storage for Logs	Ensure that all systems that store logs have adequate storage space for the logs generated.
6.5	Network	Detect	Central Log Management	Ensure that appropriate logs are being aggregated to a central log management system for analysis and review.
6.6	Network	Detect	Deploy SIEM or Log Analytic Tools	Deploy Security Information and Event Management (SIEM) or log analytic tool for log correlation and analysis.
6.7	Network	Detect	Regularly Review Logs	On a regular basis, review logs to identify anomalies or abnormal events.
6.8	Network	Detect	Regularly Tune SIEM	On a regular basis, tune your SIEM system to better identify actionable events and decrease event noise.

CSC 6: Procedures and Tools

Most free and commercial operating systems, network services, and firewall technologies offer logging capabilities. Such logging should be activated, with logs sent to centralized logging servers. Firewalls, proxies, and remote access systems (VPN, dial-up, etc.) should all be configured for verbose logging, storing all the information available for logging in the event a follow-up investigation is necessary. Furthermore, operating systems, especially those of servers, should be configured to create access control logs when a user attempts to access resources without the appropriate privileges. To evaluate whether such logging is in place, an organization should periodically scan through its logs and compare them with the asset inventory assembled as part of Critical Security Control 1 in order to ensure that each managed item actively connected to the network is periodically generating logs.

Analytical programs such as SIEM solutions for reviewing logs can provide value, but the capabilities employed to analyze audit logs are quite extensive, even including, importantly, just a cursory examination by a person. Actual correlation tools can make audit logs far more useful for subsequent manual inspection. Such tools can be quite helpful in identifying subtle attacks. However, these tools are neither a panacea nor a replacement for skilled information security personnel and system administrators. Even with automated log analysis tools, human expertise and intuition are often necessary to identify and understand attacks.

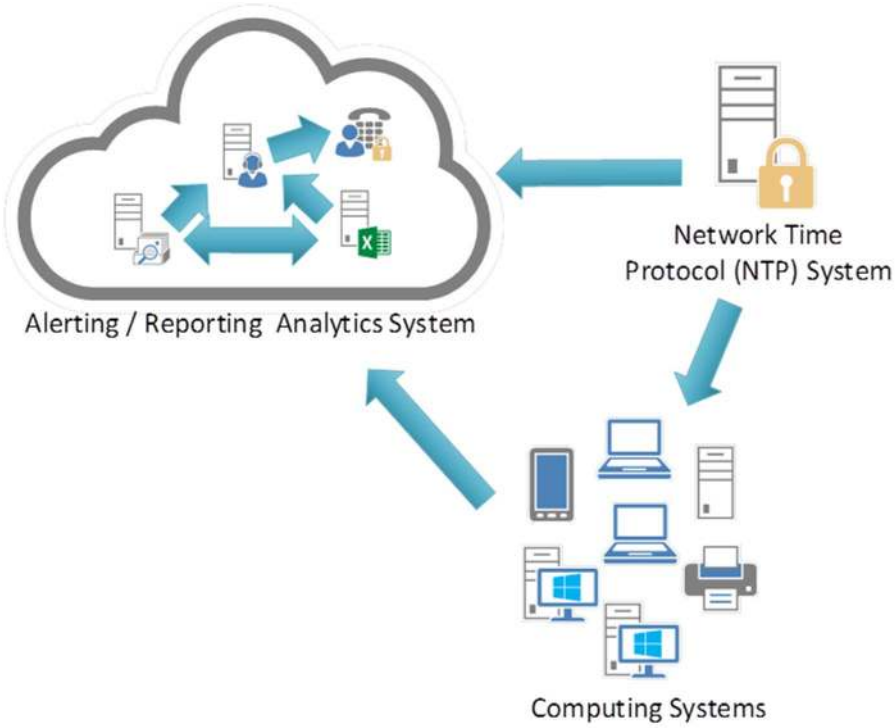


Figure 4-6: CSC 6 System Entity Relationship Diagram

4.7 CSC 7: Email and Web Browser Protections

Minimize the attack surface and the opportunities for attackers to manipulate human behaviour though their interaction with web browsers and email systems.

Why Is This Control Critical?

Web browsers and email clients are very common points of entry and attack because of their technical complexity and flexibility, and their direct interaction with users and with the other systems and websites. Content can be crafted to entice or spoof users into taking actions that greatly increase risk and allow introduction of malicious code, loss of valuable data, and other attacks. Since these applications are the main means that users interact with untrusted environments, these are potential targets for both code exploitation and social engineering.

Table 4-7: CSC 7 - Email and Web Browser Protections

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
7.1	Applications	Protect	Ensure Use of Only Fully Supported Browsers and Email Clients	Ensure that only fully supported web browsers and email clients are allowed to execute in the organization, ideally only using the latest version of the browsers and email clients provided by the vendor.
7.2	Applications	Protect	Disable Unnecessary or Unauthorized Browser or Email Client Plugins	Uninstall or disable any unauthorized browser or email client plugins or add-on applications.
7.3	Applications	Protect	Limit Use of Scripting Languages in Web Browsers and Email Clients	Ensure that only authorized scripting languages are able to run in all web browsers and email clients.
7.4	Network	Protect	Maintain and Enforce Network-Based URL Filters	Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering should be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.
7.5	Network	Protect	Subscribe to URL-Categorization service	Subscribe to URL categorization services to ensure that they are up-to-date with the most recent website category definitions available. Uncategorized sites should be blocked by default.
7.6	Network	Detect	Log all URL Requests	Log all URL requests from each of the organization's systems, whether onsite or a mobile device, in order to identify potentially malicious activity and assist incident handlers with identifying potentially compromised systems.
7.7	Network	Protect	Use of DNS Filtering Services	Use DNS filtering services to help block access to known malicious domains.
7.8	Network	Protect	Implement DMARC and Enable Receiver-Side Verification	To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the Domain Keys Identified Mail (DKIM) standards.
7.9	Network	Protect	Block Unnecessary File Types	Block all email attachments entering the organization's e-mail gateway if the file types are unnecessary for the organization's business.
7.10	Network	Protect	Sandbox All Email Attachments	Use sandboxing to analyze and block inbound email attachments with malicious behaviour.

CSC 7: Procedures and Tools

Web Browser

Cybercriminals can exploit web browsers in multiple different ways. If they have access to exploits of vulnerable browsers, they can craft malicious webpages that can exploit those vulnerabilities when browsed by an unpatched browser. Alternatively, if vulnerabilities within the browser are not available they can try to target any number of common web browser plugins that may allow them to hook into the browser or even directly into the OS. These plugins, much like any other application within your environment need to be managed and controlled, not only to know what needs to be updated but to also reduce the probability that users unintentionally install malware that might be hiding in some of these plugins and add-ons. Simple configurations of the browser can make it much harder for malware to get installed by reducing the ability of installing add-ons/plugins and also not allowing specific types of content from auto-running.

Most popular browsers employ a database of phishing and/or malware sites to protect against the most common threats. Make sure that your users enable these content filters and turn on the popup blockers. Popups are not only annoying, they also can host embedded malware directly or lure users into clicking on something using social engineering tricks. To help enforce blocking of known malicious domains, also consider subscribing to DNS filtering services to block attempts to access these websites at the network level.

Email

Email represents one the most interactive ways humans work with computers, encouraging the right behaviour is just as important as the technical settings.

Using a spam-filtering tool reduces the number of malicious emails that come into your network. Initiating a Doman-based Message Authentication, Reporting and Conformance (DMARC) helps reduce spam and phishing activities. Installing an encryption tool to secure email and communications adds another layer of user and networked based security. In addition to blocking based on the sender, it is also worthwhile to only allow certain file types that users need for their jobs. This will require some level of interfacing with different business units to understand what type of files they receive via email to ensure that there is not an interruption to their processes.

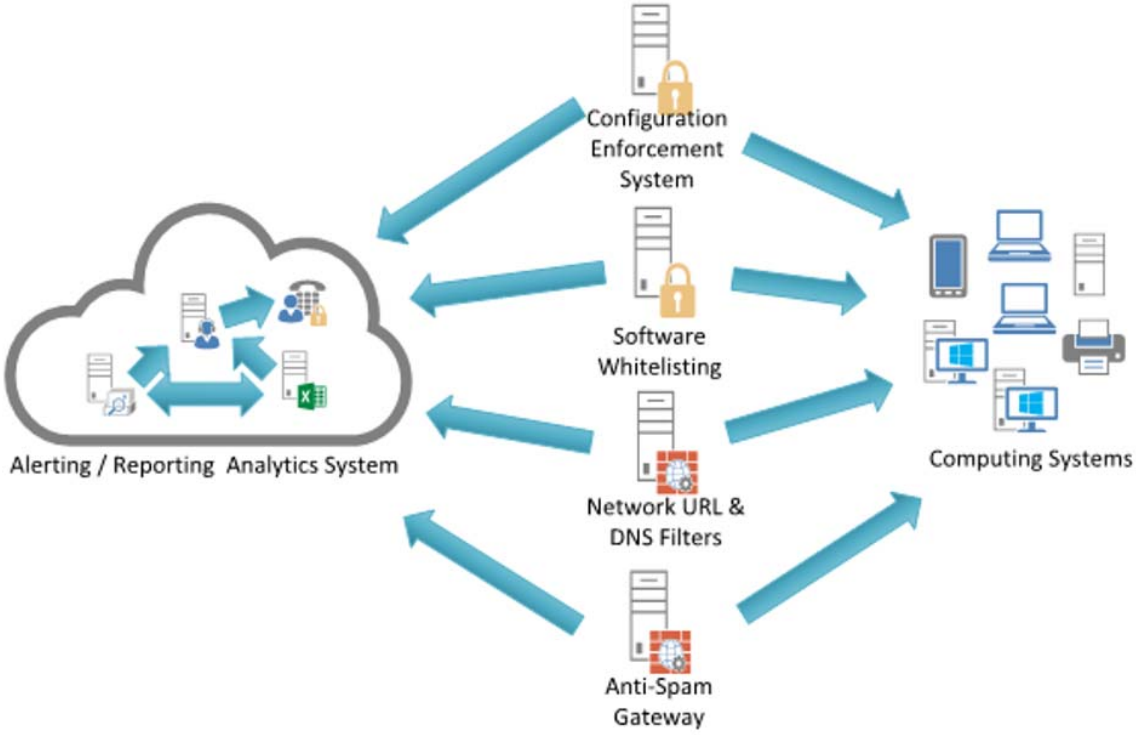


Figure 4-7: CSC 7 System Entity Relationship Diagram

4.8 CSC 8: Malware Defences

Control the installation, spread, and execution of malicious code at multiple points in the enterprise, while optimizing the use of automation to enable rapid updating of defence, data gathering, and corrective action.

Why Is This Control Critical?

Malicious software is an integral and dangerous aspect of Internet threats, as it is designed to attack the systems, devices, or data. It is fast-moving, fast-changing, and can enter through any number of points like end-user devices, email attachments, web pages, cloud services, user actions, and removable media. Modern malware is designed to avoid defences, and attack or disable them.

Malware defences should be able to operate in this dynamic environment through large-scale automation, rapid updating, and integration with processes like Incident Response. They should also be deployed at multiple possible points-of-attack to detect, stop the movement of, or control the execution of malicious software. Enterprise endpoint security suites provide administrative features to verify that all defences are active and current on every managed system.

Table 4-8: CSC 8 - Malware Defences

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
8.1	Devices	Protect	Utilize Centrally Managed Anti-malware Software	Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.
8.2	Devices	Protect	Ensure Anti-Malware Software and Signatures are Updated	Ensure that the organization's anti-malware software updates its scanning engine and signature database on a regular basis.
8.3	Devices	Detect	Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies	Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.
8.4	Devices	Detect	Configure Anti-Malware Scanning of Removable	Configure devices so that they automatically conduct an anti-malware scan of removable media when inserted or connected.
8.5	Devices	Protect	Configure Devices to Not Auto-run Content	Configure devices to not auto-run content from removable media.
8.6	Devices	Detect	Centralize Anti-malware Logging	Send all malware detection events to enterprise anti-malware administration tools and event log servers for analysis and alerting.
8.7	Network	Detect	Enable DNS Query Logging	Enable Domain Name System (DNS) query logging to detect hostname lookups for known malicious domains.
8.8	Devices	Detect	Enable Command-line Audit Logging	Enable command-line audit logging for command shells, such as Microsoft PowerShell and Bash.

CSC 8: Procedures and Tools

To ensure anti-virus signatures are up to date, organizations use automation. They use the built-in administrative features of enterprise endpoint security suites to verify that anti-virus, anti-spyware, and host-based IDS features are active on every managed system. They run automated assessments daily and review the results to find and mitigate systems that have deactivated such protections, as well as systems that do not have the latest malware definitions.

Being able to block malicious applications is only part of this control, there is also a big focus on collecting the logs to help organizations understand what happened within their environment, and this includes ensuring that there is logging enabled for various command line tools, such as Windows PowerShell and Bash. As malicious actors continue to develop their methodologies, many are starting to take a "live-off–the-land" approach to minimize the likelihood of being caught. Enabling logging will make it significantly easier for the organization to follow the events and how they, what happened and how it happened.

NOTE: Powershell and Python are the names of products supplied by a variety of parties. Some versions are proprietary, others are free/open-source software. Windows® is a registered trademark of Microsoft Corporation. This information is given for the convenience of users of the present document and does not constitute an endorsement by ETSI of the product named. Equivalent products may be used if they can be shown to lead to the same results.

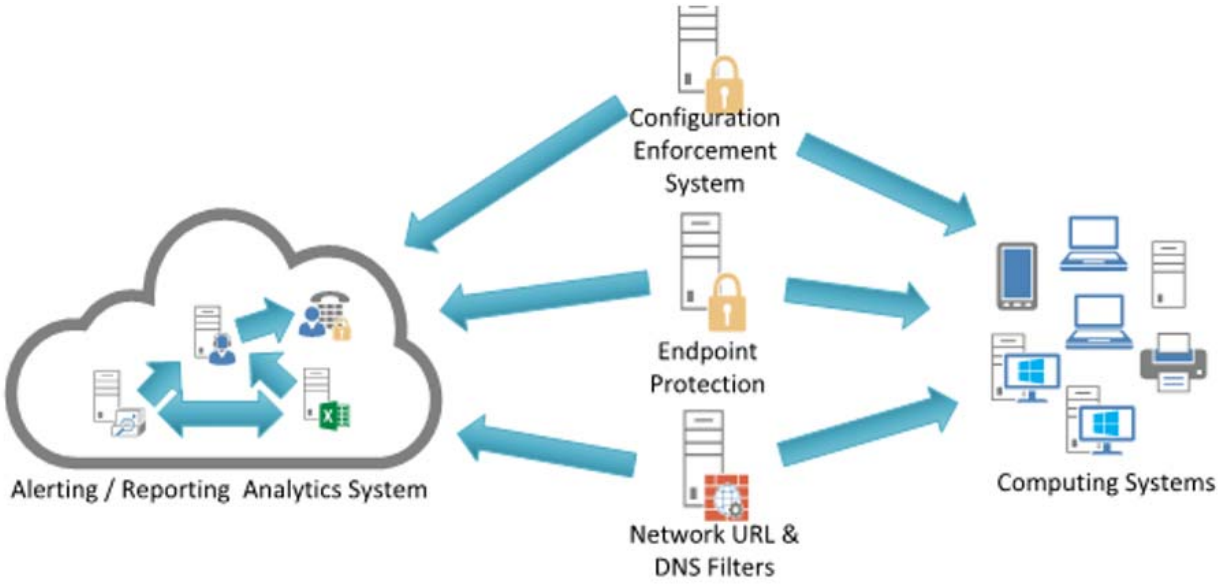


Figure 4-8: CSC 8 System Entity Relationship Diagram

4.9 CSC 9: Limitation and Control of Network Ports, Protocols, and Services

Manage (track/control/correct) the ongoing operational use of ports, protocols, and services on networked devices in order to minimize windows of vulnerability available to attackers.

Why Is This Control Critical?

Attackers search for remotely accessible network services that are vulnerable to exploitation. Common examples include poorly configured web servers, mail servers, file and print services, and Domain Name System (DNS) servers installed by default on a variety of different device types, often without a business need for the given service. Many software packages automatically install services and turn them on as part of the installation of the main software package without informing a user or administrator that the services have been enabled. Attackers scan for such services and attempt to exploit these services, often attempting to exploit default user IDs and passwords or widely available exploitation code.

Table 4-9: CSC 9 - Limitation and Control of Network Ports, Protocols, and Services

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
9.1	Devices	Identify	Associate Active Ports, Services and Protocols to Asset Inventory	Associate active ports, services and protocols to the hardware assets in the asset inventory.
9.2	Devices	Protect	Ensure Only Approved Ports, Protocols and Services Are Running	Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.
9.3	Devices	Detect	Perform Regular Automated Port Scans	Perform automated port scans on a regular basis against all systems and alert if unauthorized ports are detected on a system.
9.4	Devices	Protect	Apply Host-based Firewalls or Port Filtering	Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.
9.5	Devices	Protect	Implement Application Firewalls	Place application firewalls in front of any critical servers to verify and validate the traffic going to the server. Any unauthorized traffic should be blocked and logged.

CSC 9: Procedures and Tools

Port scanning tools are used to determine which services are listening on the network for a range of target systems. In addition to determining which ports are open, effective port scanners can be configured to identify the version of the protocol and service listening on each discovered port. This list of services and their versions are compared against an inventory of services necessary by the organization for each server and workstation in an asset management system. Recently added features in these port scanners are being used to determine the changes in services offered by scanned machines on the network since the previous scan, helping security personnel identify differences over time.

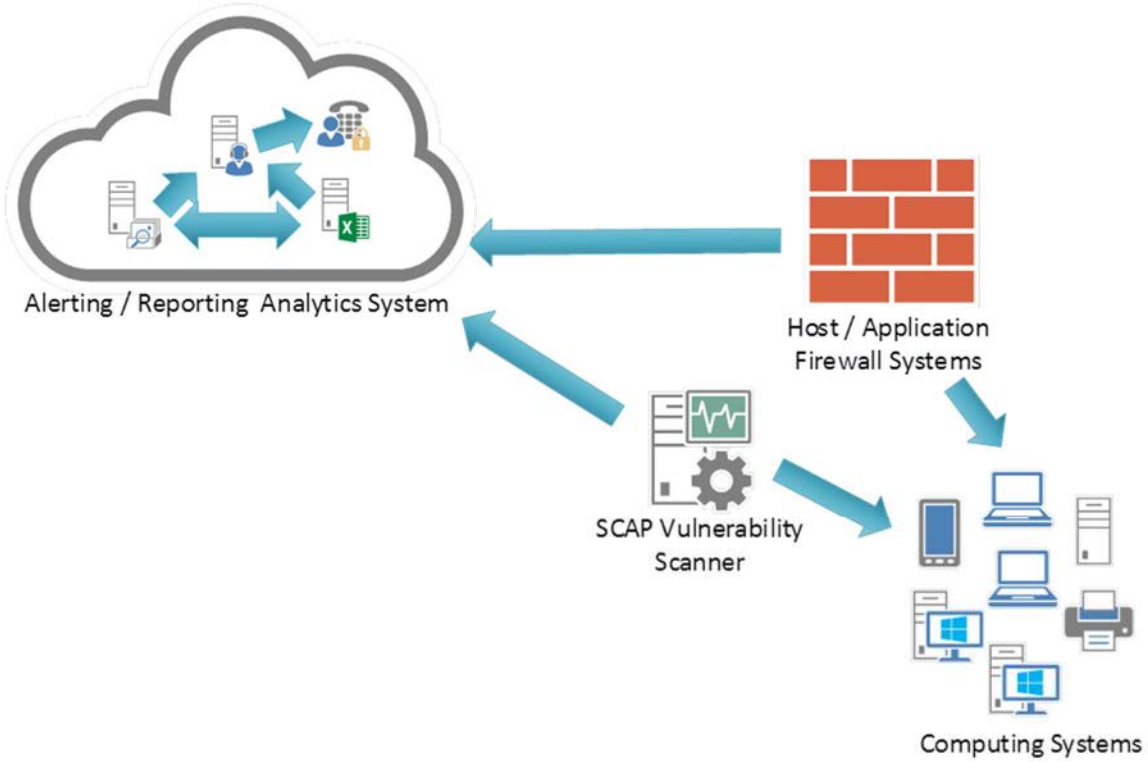


Figure 4-9: CSC 9 System Entity Relationship Diagram

4.10 CSC 10: Data Recovery Capabilities

The processes and tools used to properly back up critical information with a proven methodology for timely recovery of it.

Why Is This Control Critical?

When attackers compromise machines, they often make significant changes to configurations and software. Sometimes attackers also make subtle alterations of data stored on compromised machines, potentially jeopardizing organizational effectiveness with polluted information. When the attackers are discovered, it can be extremely difficult for organizations without a trustworthy data recovery capability to remove all aspects of the attacker's presence on the machine.

Table 4-10: CSC 10 - Data Recovery Capabilities

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
10.1	Data	Protect	Ensure Regular Automated Back Ups	Ensure that all system data is automatically backed up on regular basis.
10.2	Data	Protect	Perform Complete System Backups	Ensure that each of the organization's key systems are backed up as a complete system, through processes such as imaging, to enable the quick recovery of an entire system.
10.3	Data	Protect	Test Data on Backup Media	Test data integrity on backup media on a regular basis by performing a data restoration process to ensure that the backup is properly working.
10.4	Data	Protect	Protect Backups	Ensure that backups are properly protected via physical security or encryption when they are stored, as well as when they are moved across the network. This includes remote backups and cloud services.
10.5	Data	Protect	Ensure Backups Have At least One Non-Continuously Addressable Destination	Ensure that all backups have at least one backup destination that is not continuously addressable through operating system calls.

CSC 10: Procedures and Tools

Once per quarter (or whenever new backup equipment is purchased), a testing team should evaluate a random sample of system backups by attempting to restore them on a test bed environment. The restored systems should be verified to ensure that the operating system, application, and data from the backup are all intact and functional.

In the event of malware infection, restoration procedures should use a version of the backup that is believed to predate the original infection.

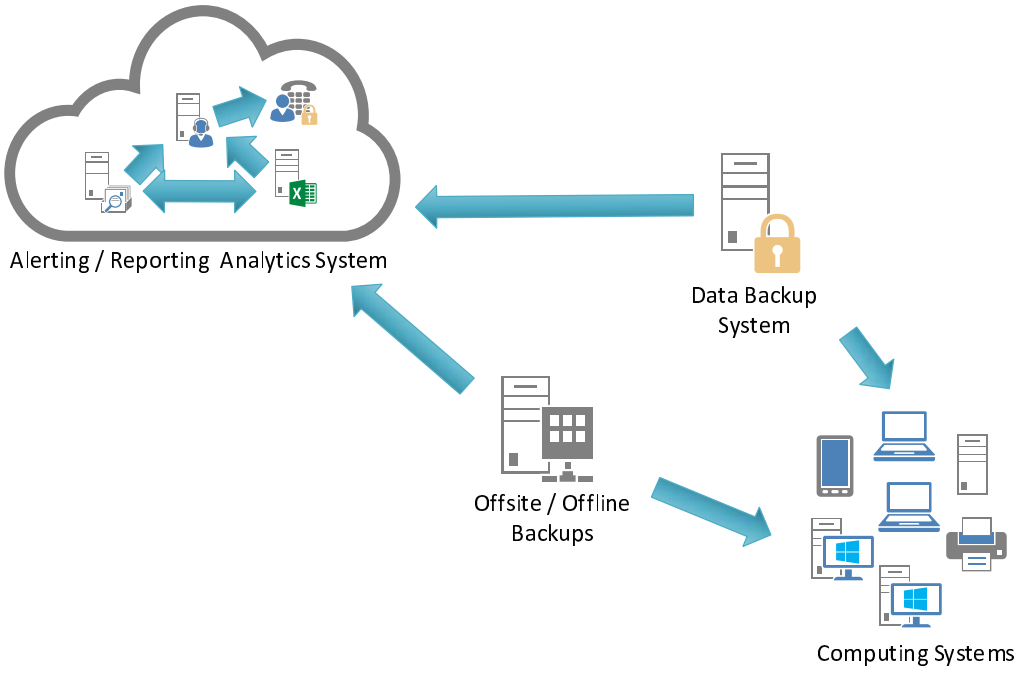


Figure 4-10: CSC 10 System Entity Relationship Diagram

4.11 CSC 11: Secure Configurations for Network Devices such as Firewalls, Routers, and Switches

Establish, implement, and actively manage (track, report on, correct) the security configuration of network infrastructure devices using a rigorous configuration management and change control process in order to prevent attackers from exploiting vulnerable services and settings.

Why Is This Control Critical?

As delivered from manufacturers and resellers, the default configurations for network infrastructure devices are geared for ease-of-deployment and ease-of-use - not security. Open services and ports, default accounts (including service accounts) or passwords, support for older (vulnerable) protocols, pre-installation of unneeded software; all can be exploitable in their default state. The management of the secure configurations for networking devices is not a one-time event, but a process that involves regularly re-evaluating not only the configuration items but also the allowed traffic flows.

Attackers take advantage of network devices becoming less securely configured over time as users demand exceptions for specific business needs. Sometimes the exceptions are deployed and then left undone when they are no longer applicable to the business needs. In some cases, the security risk of the exception is neither properly analyzed nor measured against the associated business need and can change over time. Attackers search for vulnerable default settings, gaps or inconsistencies in firewall rule sets, routers, and switches and use those vulnerabilities to penetrate defences. They exploit flaws in these devices to gain access to networks, redirect traffic on a network, and intercept information while in transmission. Through such actions, the attacker gains access to sensitive data, alters important information, or even uses a compromised machine to pose as another trusted system on the network.

Table 4-11: CSC 11 - Secure Configurations for Network Devices such as Firewalls, Routers, and Switches

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
11.1	Network	Identify	Maintain Standard Security Configurations for Network Devices	Maintain standard, documented security configuration standards for all authorized network devices.
11.2	Network	Identify	Document Traffic Configuration Rules	All configuration rules that allow traffic to flow through network devices should be documented in a configuration management system with a specific business reason for each rule, a specific individual's name responsible for that business need, and an expected duration of the need.
11.3	Network	Detect	Use Automated Tools to Verify Standard Device Configurations and Detect Changes	Compare all network device configuration against approved security configurations defined for each network device in use and alert when any deviations are discovered.
11.4	Network	Protect	Install the Latest Stable Version of Any Security-related Updates on All Network Devices	Install the latest stable version of any security-related updates on all network devices.
11.5	Network	Protect	Manage Network Devices Using Multi-Factor Authentication and Encrypted Sessions	Manage all network devices using multi-factor authentication and encrypted sessions.
11.6	Network	Protect	Use Dedicated Workstations For All Network Administrative Tasks	Ensure network engineers use a dedicated machine for all administrative tasks or tasks requiring elevated access. This machine should be segmented from the organization's primary network and not be allowed Internet access. This machine should not be used for reading email, composing documents, or surfing the Internet.
11.7	Network	Protect	Manage Network Infrastructure Through a Dedicated Network	Manage the network infrastructure across network connections that are separated from the business use of that network, relying on separate VLANs or, preferably, on entirely different physical connectivity for management sessions for network devices.

CSC 11: Procedures and Tools

Some organizations use commercial tools that evaluate the rule set of network filtering devices to determine whether they are consistent or in conflict, providing an automated sanity check of network filters and search for errors in rule sets or access controls lists (ACLs) that may allow unintended services through the device. Such tools should be run each time significant changes are made to firewall rule sets, router ACLs, or other filtering technologies.

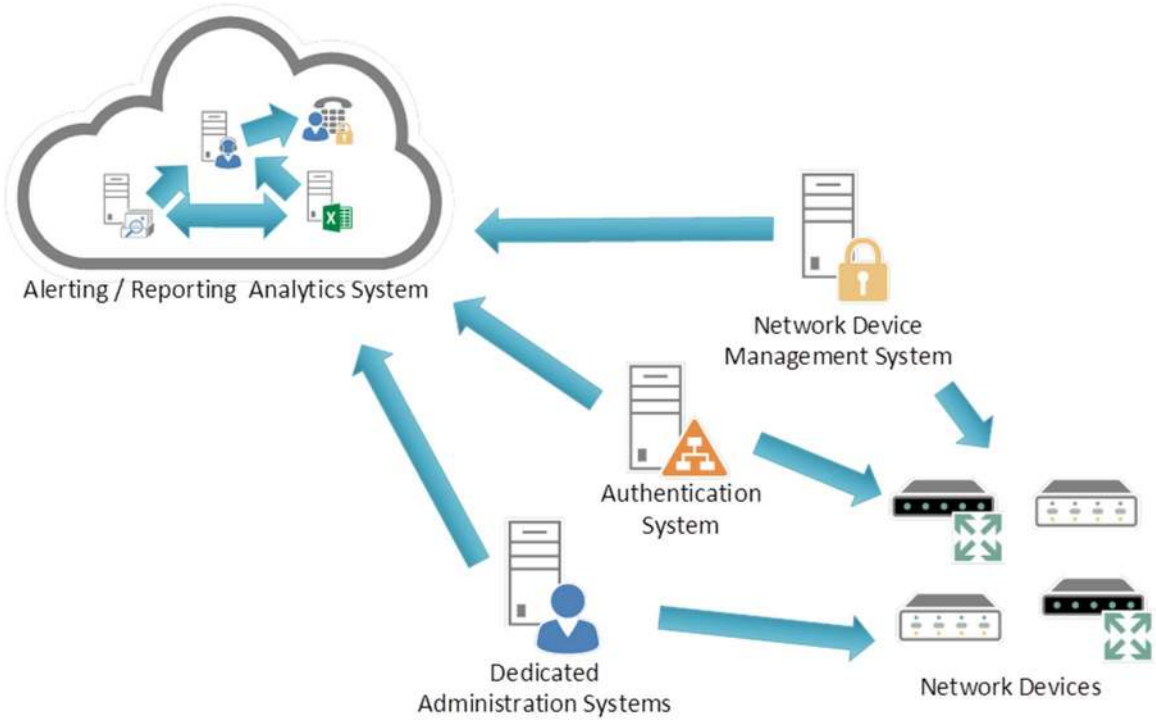


Figure 4-11: CSC 11 System Entity Relationship Diagram

4.12 CSC 12: Boundary Defence

Detect/prevent/correct the flow of information transferring networks of different trust levels with a focus on security-damaging data.

Why Is This Control Critical?

Attackers focus on exploiting systems that they can reach across the internet, including not only DMZ systems but also workstations and laptop computers that pull content from the internet through network boundaries. Threats such as organized crime groups and nation-states use configuration and architectural weaknesses found on perimeter systems, network devices, and Internet-accessing client machines to gain initial access into an organization. Then, with a base of operations on these machines, attackers often pivot to get deeper inside the boundary to steal or change information or to set up a persistent presence for later attacks against internal hosts. Additionally, many attacks occur between business partner networks, sometimes referred to as extranets, as attackers hop from one organization's network to another, exploiting vulnerable systems on extranet perimeters.

To control the flow of traffic through network borders and police content by looking for attacks and evidence of compromised machines, boundary defences should be multi-layered, relying on firewalls, proxies, DMZ perimeter networks, and network-based IPS and IDS. It is also critical to filter both inbound and outbound traffic.

It should be noted that boundary lines between internal and external networks are diminishing as a result of increased interconnectivity within and between organizations as well as the rapid rise in deployment of wireless technologies. These blurring lines sometimes allow attackers to gain access inside networks while bypassing boundary systems. However, even with this blurring of boundaries, effective security deployments still rely on carefully configured boundary defences that separate networks with different threat levels, sets of users, data and levels of control. And despite the blurring of internal and external networks, effective multi-layered defences of perimeter networks help lower the number of successful attacks, allowing security personnel to focus on attackers who have devised methods to bypass boundary restrictions.

Table 4-12: CSC 12 - Boundary Defence

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
12.1	Network	Identify	Maintain an Inventory of Network Boundaries	Maintain an up-to-date inventory of all of the organization's network boundaries.
12.2	Network	Detect	Scan for Unauthorized Connections across Trusted Network Boundaries	Perform regular scans from outside each trusted network boundary to detect any unauthorized connections which are accessible across the boundary.
12.3	Network	Protect	Deny Communications with Known Malicious IP Addresses	Deny communications with known malicious or unused Internet IP addresses and limit access only to trusted and necessary IP address ranges at each of the organization's network boundaries.
12.4	Network	Protect	Deny Communication over Unauthorized Ports	Deny communication over unauthorized TCP or UDP ports or application traffic to ensure that only authorized protocols are allowed to cross the network boundary in or out of the network at each of the organization's network boundaries.
12.5	Network	Detect	Configure Monitoring Systems to Record Network Packets	Configure monitoring systems to record network packets passing through the boundary at each of the organization's network boundaries.
12.6	Network	Detect	Deploy Network-based IDS Sensors	Deploy network-based Intrusion Detection Systems (IDS) sensors to look for unusual attack mechanisms and detect compromise of these systems at each of the organization's network boundaries.
12.7	Network	Protect	Deploy Network-Based Intrusion Prevention Systems	Deploy network-based Intrusion Prevention Systems (IPS) to block malicious network traffic at each of the organization's network boundaries.
12.8	Network	Detect	Deploy NetFlow Collection on Networking Boundary Devices	Enable the collection of NetFlow and logging data on all network boundary devices.
12.9	Network	Detect	Deploy Application Layer Filtering Proxy Server	Ensure that all network traffic to or from the Internet passes through an authenticated application layer proxy that is configured to filter unauthorized connections.
12.10	Network	Detect	Decrypt Network Traffic at Proxy	Decrypt all encrypted network traffic at the boundary proxy prior to analyzing the content. However, the organization may use whitelists of allowed sites that can be accessed through the proxy without decrypting the traffic.
12.11	Users	Protect	Require All Remote Logins to Use Multi-factor Authentication	Require all remote login access to the organization's network to encrypt data in transit and use multi-factor authentication.
12.12	Devices	Protect	Manage All Devices Remotely Logging into Internal Network	Scan all enterprise devices remotely logging into the organization's network prior to accessing the network to ensure that each of the organization's security policies has been enforced in the same manner as local network devices.

CSC 12: Procedures and Tools

The boundary defences included in this control build on Critical Security Control 9. The additional recommendations here focus on improving the overall architecture and implementation of both internet and internal network boundary points. Internal network segmentation is central to this control because once inside a network, many intruders attempt to target the most sensitive machines. Usually, internal network protection is not set up to defend against an internal attacker. Setting up even a basic level of security segmentation across the network and protecting each segment with a proxy and a firewall will greatly reduce an intruder's access to the other parts of the network.

One element of this control can be implemented using free or commercial IDS and sniffers to look for attacks from external sources directed at DMZ and internal systems, as well as attacks originating from internal systems against the DMZ or internet. Security personnel should regularly test these sensors by launching vulnerability-scanning tools against them to verify that the scanner traffic triggers an appropriate alert. The captured packets of the IDS sensors should be reviewed using an automated script each day to ensure that log volumes are within expected parameters and that the logs are formatted properly and have not been corrupted.

Additionally, packet sniffers should be deployed on DMZs to look for Hypertext Transfer Protocol (HTTP) traffic that bypasses HTTP proxies. By sampling traffic regularly, such as over a three-hour period once a week, information security personnel can search for HTTP traffic that is neither sourced by nor destined for a DMZ proxy, implying that the requirement for proxy use is being bypassed.

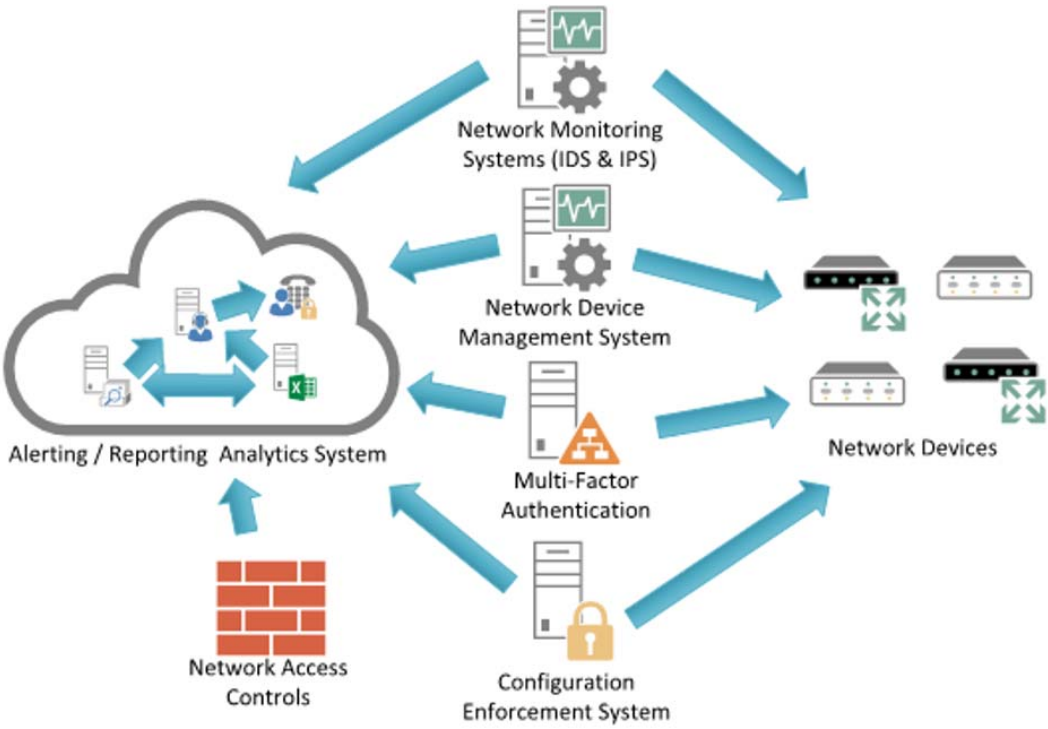


Figure 4-12: CSC 12 System Entity Relationship Diagram

4.13 CSC 13: Data Protection

The processes and tools used to prevent data exfiltration, mitigate the effects of exfiltrated data, and ensure the privacy and integrity of sensitive information.

Why Is This Control Critical?

Data resides in many places. Protection of that data is best achieved through the application of a combination of encryption, integrity protection and data loss prevention techniques. As organizations continue their move towards cloud computing and mobile access, it is important that proper care be taken to limit and report on data exfiltration while also mitigating the effects of data compromise.

Some organizations do not carefully identify and separate their most sensitive and critical assets from less sensitive, publicly accessible information on their internal networks. In many environments, internal users have access to all or most of the critical assets. Sensitive assets may also include systems that provide management and control of physical systems (e.g. SCADA). Once attackers have penetrated such a network, they can easily find and exfiltrate important information, cause physical damage, or disrupt operations with little resistance. For example, in several high-profile breaches over the past two years, attackers were able to gain access to sensitive data stored on the same servers with the same level of access as far less important data. There are also examples of using access to the corporate network to gain access to, then control over, physical assets and cause damage.

Table 4-13: CSC 13 - Data Protection

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
13.1	Data	Identify	Maintain an Inventory Sensitive Information	Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.
13.2	Data	Protect	Remove Sensitive Data or Systems Not Regularly Accessed by Organization	Remove sensitive data or systems not regularly accessed by the organization from the network. These systems should only be used as stand-alone systems (disconnected from the network) by the business unit needing to occasionally use the system or completely virtualized and powered off until needed.
13.3	Data	Detect	Monitor and Block Unauthorized Network Traffic	Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.
13.4	Data	Protect	Only Allow Access to Authorized Cloud Storage or Email Providers	Only allow access to authorized cloud storage or email providers.
13.5	Data	Detect	Monitor and Detect Any Unauthorized Use of Encryption	Monitor all traffic leaving the organization and detect any unauthorized use of encryption.
13.6	Data	Protect	Encrypt the Hard Drive of All Mobile Devices	Utilize approved whole disk encryption software to encrypt the hard drive of all mobile devices.
13.7	Data	Protect	Manage USB Devices	If USB storage devices are necessary, enterprise software should be used that can configure systems to allow the use of specific devices. An inventory of such devices should be maintained.
13.8	Data	Protect	Manage System's External Removable Media's Read/write Configurations	Configure systems not to write data to external removable media, if there is no business need for supporting such devices.
13.9	Data	Protect	Encrypt Data on USB Storage Devices	If USB storage devices are necessary, all data stored on such devices should be encrypted while at rest.

CSC 13: Procedures and Tools

It is important that an organization understand what its sensitive information is, where it resides, and who needs access to it. To derive sensitivity levels, organizations need to put together a list of the key types of data and the overall importance to the organization. This analysis would be used to create an overall data classification scheme for the organization. Organizations should define labels, such as "Sensitive", "Business Confidential" and "Public", and classify their data according to those labels. Once the private information has been identified, it can then be further subdivided based on the impact it would have to the organization if it were compromised.

Once the sensitivity of the data has been identified, create a data inventory or mapping that identifies business applications and the servers that house those applications. The network then needs to be segmented so that systems of the same sensitivity level are on the same network and segmented from systems with different trust levels. If possible, firewalls need to control access to each segment.

Access to data should be based on job requirements and a need-to-know basis. Job requirements should be created for each user group to determine what information the group needs access to in order to perform its jobs. Based on the requirements, access should only be given to the data segments or servers that are needed for each job function. Detailed logging should be turned on for servers in order to track access and allow for security personnel to examine incidents in which data was improperly accessed.

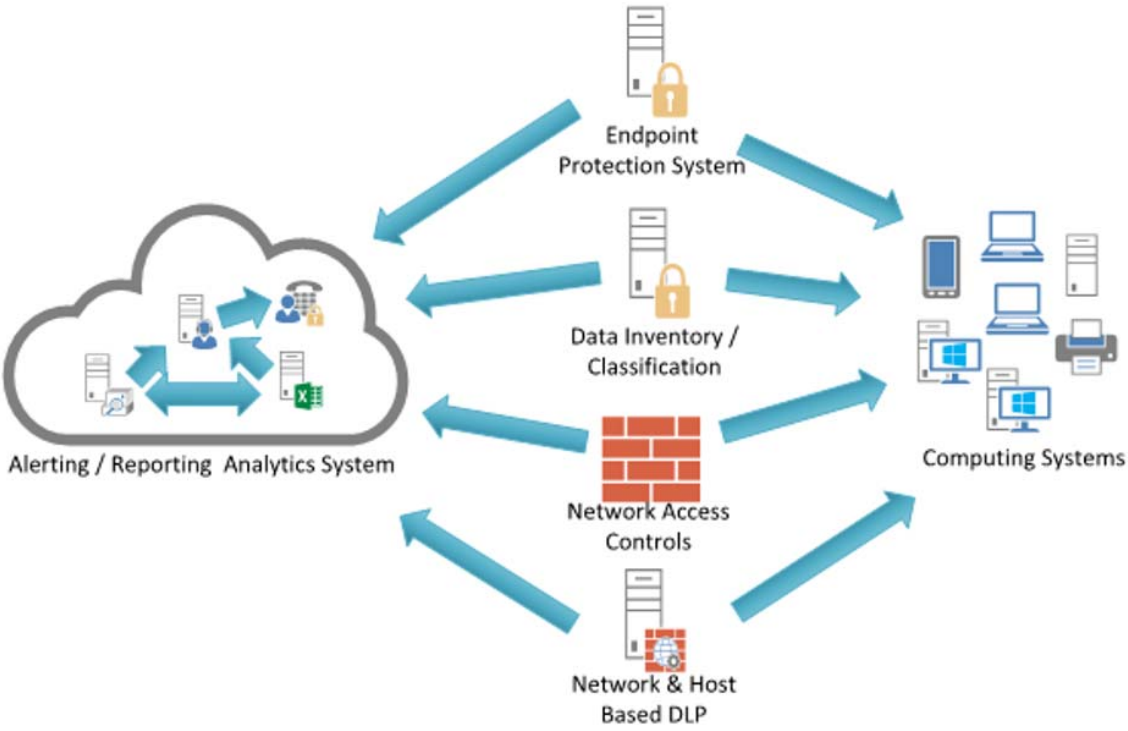


Figure 4-13: CSC 13 System Entity Relationship Diagram

4.14 CSC 14: Controlled Access Based on the Need to Know

The processes and tools used to track/control/prevent/correct secure access to critical assets (e.g. information, resources, systems) according to the formal determination of which persons, computers, and applications have a need and right to access these critical assets based on an approved classification.

Why Is This Control Critical?

Encrypting data provides a level of assurance that even if data is compromised, it is impractical to access the plaintext without significant resources; however, controls should also be put in place to mitigate the threat of data exfiltration in the first place. Many attacks occurred across the network, while others involved physical theft of laptops and other equipment holding sensitive information. Yet, in many cases, the victims were not aware that the sensitive data were leaving their systems because they were not monitoring data outflows. The movement of data across network boundaries both electronically and physically should be carefully scrutinized to minimize its exposure to attackers.

The loss of control over protected or sensitive data by organizations is a serious threat to business operations and a potential threat to national security. While some data are leaked or lost as a result of theft or espionage, the vast majority of these problems result from poorly understood data practices, a lack of effective policy architectures, and user error. Data loss can even occur as a result of legitimate activities such as e-Discovery during litigation, particularly when records retention practices are ineffective or non-existent.

The adoption of data encryption, both in transit and at rest, provides mitigation against data compromise. This is true if proper care has been taken in the processes and technologies associated with the encryption operations. An example of this is the management of cryptographic keys used by the various algorithms that protect data. The process for generation, use and destruction of keys should be based on proven processes as defined in standards such as NIST SP 800-57 [i.2].

Care should also be taken to ensure that products used within an enterprise implement well known and vetted cryptographic algorithms, as identified by NIST. Re-evaluation of the algorithms and key sizes used within the enterprise on an annual basis is also recommended to ensure that organizations are not falling behind in the strength of protection applied to their data.

For organizations that are moving data to the cloud, it is important to understand the security controls applied to data in the cloud multi-tenant environment, and determine the best course of action for application of encryption controls and security of keys. When possible, keys should be stored within secure containers such as Hardware Security Modules (HSMs).

Data loss prevention (DLP) refers to a comprehensive approach covering people, processes, and systems that identify, monitor, and protect data in use (e.g. endpoint actions), data in motion (e.g. network actions), and data at rest (e.g. data storage) through deep content inspection and with a centralized management framework. Over the last several years, there has been a noticeable shift in attention and investment from securing the network to securing systems within the network, and to securing the data itself. DLP controls are based on policy, and include classifying sensitive data, discovering that data across an enterprise, enforcing controls, and reporting and auditing to ensure policy compliance.

Table 4-14: CSC 14 - Controlled Access Based on the Need to Know

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
14.1	Network	Protect	Segment the Network Based on Sensitivity	Segment the network based on the label or classification level of the information stored on the servers, locate all sensitive information on separated Virtual Local Area Networks (VLANs).
14.2	Network	Protect	Enable Firewall Filtering Between VLANs	Enable firewall filtering between VLANs to ensure that only authorized systems are able to communicate with other systems necessary to fulfill their specific responsibilities.
14.3	Network	Protect	Disable Workstation to Workstation Communication	Disable all workstation to workstation communication to limit an attacker's ability to move laterally and compromise neighbouring systems, through technologies such as Private VLANs or micro segmentation.
14.4	Data	Protect	Encrypt All Sensitive Information in Transit	Encrypt all sensitive information in transit.
14.5	Data	Detect	Utilize an Active Discovery Tool to Identify Sensitive Data	Utilize an active discovery tool to identify all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider and update the organization's sensitive information inventory.
14.6	Data	Protect	Protect Information through Access Control Lists	Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.
14.7	Data	Protect	Enforce Access Control to Data through Automated Tools	Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when the data is copied off a system.
14.8	Data	Protect	Encrypt Sensitive Information at Rest	Encrypt all sensitive information at rest using a tool that requires a secondary authentication mechanism not integrated into the operating system, in order to access the information.
14.9	Data	Detect	Enforce Detail Logging for Access or Changes to Sensitive Data	Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).

CSC 14: Procedures and Tools

Commercial tools are available to support enterprise management of encryption and key management within an enterprise and include the ability to support implementation of encryption controls within cloud and mobile environments.

Definition of life cycle processes and roles and responsibilities associated with key management should be undertaken by each organization.

Commercial DLP solutions are available to look for exfiltration attempts and detect other suspicious activities associated with a protected network holding sensitive information. Organizations deploying such tools should carefully inspect their logs and follow up on any discovered attempts, even those that are successfully blocked, to transmit sensitive information out of the organization without authorization.

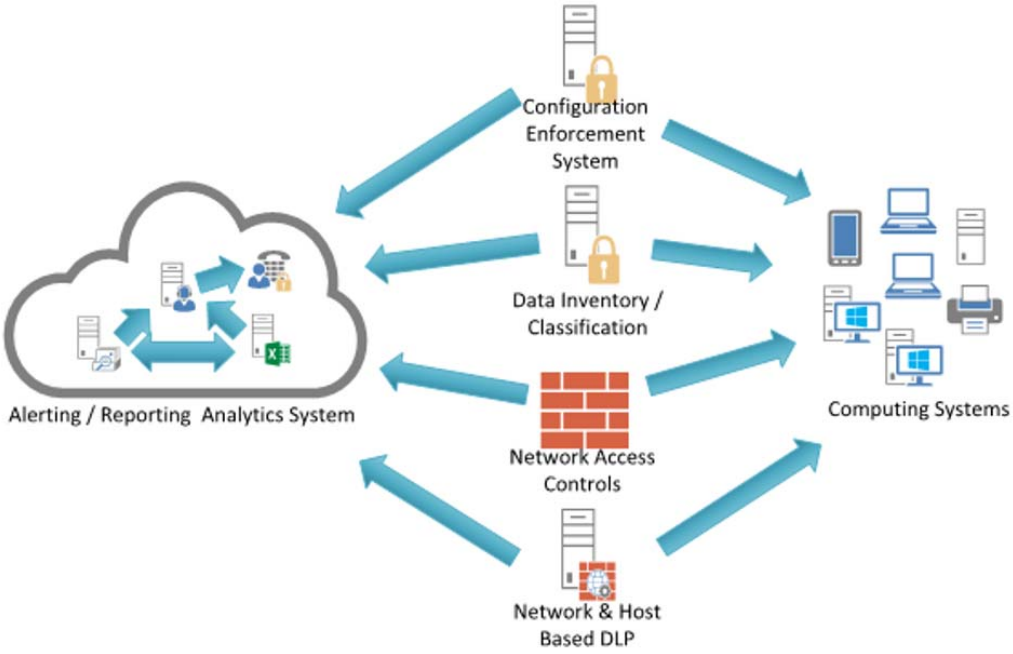


Figure 4-14: CSC 14 System Entity Relationship Diagram

4.15 CSC 15: Wireless Access Control

The processes and tools used to track/control/prevent/correct the security use of wireless local area networks (WLANs), access points, and wireless client systems.

Why Is This Control Critical?

Major thefts of data have been initiated by attackers who have gained wireless access to organizations from outside the physical building, bypassing organizations' security perimeters by connecting wirelessly to access points inside the organization. Wireless clients accompanying travellers are infected on a regular basis through remote exploitation while on public wireless networks found in airports and cafes. Such exploited systems are then used as back doors when they are reconnected to the network of a target organization. Other organizations have reported the discovery of unauthorized wireless access points on their networks, planted and sometimes hidden for unrestricted access to an internal network. Because they do not require direct physical connections, wireless devices are a convenient vector for attackers to maintain long-term access into a target environment.

Table 4-15: CSC 15 - Wireless Access Control

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
15.1	Network	Identify	Maintain an Inventory of Authorized Wireless Access Points	Maintain an inventory of authorized wireless access points connected to the wired network.
15.2	Network	Detect	Detect Wireless Access Points Connected to the Wired Network	Configure network vulnerability scanning tools to detect and alert on unauthorized wireless access points connected to the wired network.
15.3	Network	Detect	Use a Wireless Intrusion Detection System	Use a wireless intrusion detection system (WIDS) to detect and alert on unauthorized wireless access points connected to the network.
15.4	Devices	Protect	Disable Wireless Access on Devices if it is Not Necessary	Disable wireless access on devices that do not have a business purpose for wireless access.
15.5	Devices	Protect	Limit Wireless Access on Client Devices	Configure wireless access on client machines that do have an essential wireless business purpose, to allow access only to authorized wireless networks and to restrict access to other wireless networks.
15.6	Devices	Protect	Disable Peer-to-peer Wireless Network Capabilities on Wireless Clients	Disable peer-to-peer (adhoc) wireless network capabilities on wireless clients.
15.7	Network	Protect	Leverage the Advanced Encryption Standard (AES) to Encrypt Wireless Data	Leverage the Advanced Encryption Standard (AES) to encrypt wireless data in transit.
15.8	Network	Protect	Use Wireless Authentication Protocols that Require Mutual, Multi-Factor Authentication	Ensure that wireless networks use authentication protocols such as Extensible Authentication Protocol-Transport Layer Security (EAP/TLS), that requires mutual, multi-factor authentication.
15.9	Devices	Protect	Disable Wireless Peripheral Access to Devices	Disable wireless peripheral access of devices (such as Bluetooth and NFC), unless such access is necessary for a business purpose.
15.10	Network	Protect	Create Separate Wireless Network for Personal and Untrusted Devices	Create a separate wireless network for personal or untrusted devices. Enterprise access from this network should be treated as untrusted and filtered and audited accordingly.

CSC 15: Procedures and Tools

Effective organizations run commercial wireless scanning, detection, and discovery tools as well as commercial wireless intrusion detection systems.

Additionally, the security team should periodically capture wireless traffic from within the borders of a facility and use free and commercial analysis tools to determine whether the wireless traffic was transmitted using weaker protocols or encryption than the organization mandates. When devices relying on weak wireless security settings are identified, they should be found within the organization's asset inventory and either reconfigured more securely or denied access to the organization network.

Additionally, the security team should employ remote management tools on the wired network to pull information about the wireless capabilities and devices connected to managed systems.

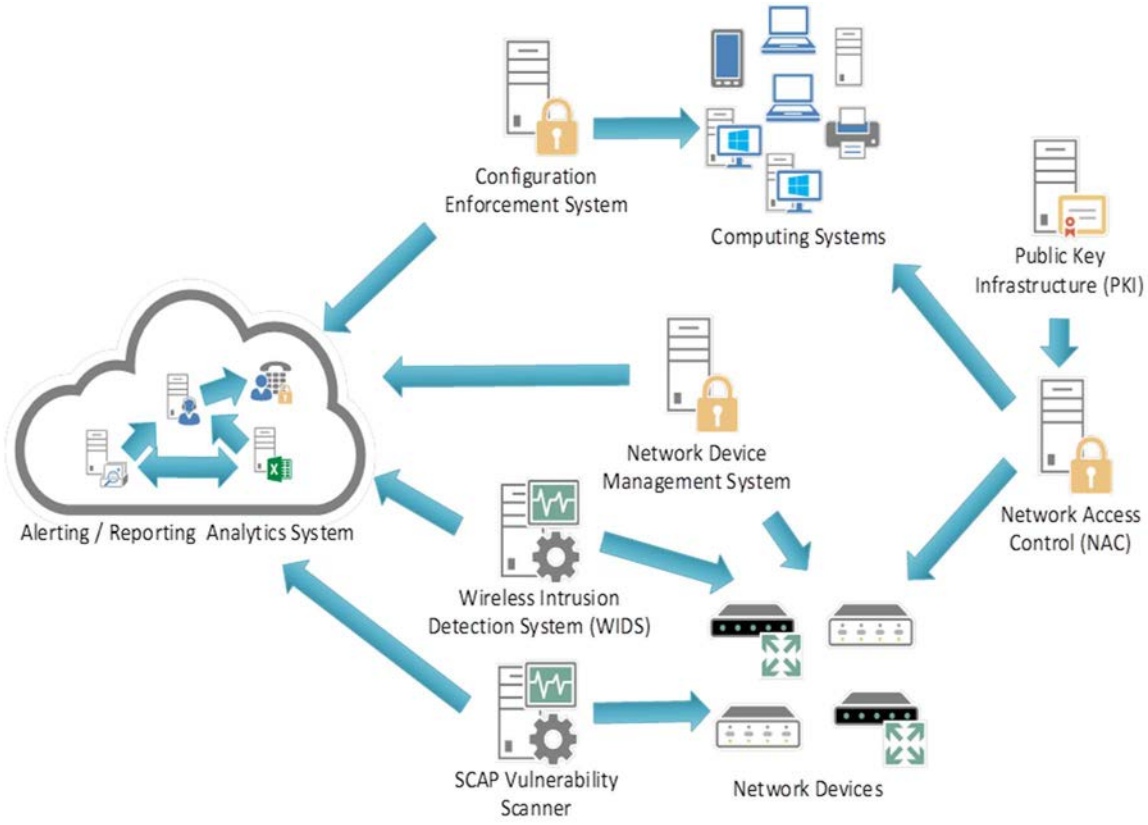


Figure 4-15: CSC 15 System Entity Relationship Diagram

4.16 CSC 16: Account Monitoring and Control

Actively manage the life cycle of system and application accounts - their creation, use, dormancy, deletion - in order to minimize opportunities for attackers to leverage them.

Why Is This Control Critical?

Attackers frequently discover and exploit legitimate but inactive user accounts to impersonate legitimate users, thereby making discovery of attacker behaviour difficult for security personnel watchers. Accounts of contractors and employees who have been terminated and accounts formerly set up for Red Team testing (but not deleted afterwards) have often been misused in this way. Additionally, some malicious insiders or former employees have gained access to accounts left behind in a system long after contract expiration, maintaining their access to an organization's computing system and sensitive data for unauthorized and sometimes malicious purposes.

Table 4-16: CSC 16 - Account Monitoring and Control

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
16.1	Users	Identify	Maintain an Inventory of Authentication Systems	Maintain an inventory of each of the organization's authentication systems, including those located onsite or at a remote service provider.
16.2	Users	Protect	Configure Centralized Point of Authentication	Configure access for all accounts through as few centralized points of authentication as possible, including network, security, and cloud systems.
16.3	Users	Protect	Require Multi-factor Authentication	Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.
16.4	Users	Protect	Encrypt or Hash all Authentication Credentials	Encrypt or hash with a salt all authentication credentials when stored.
16.5	Users	Protect	Encrypt Transmittal of Username and Authentication Credentials	Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.
16.6	Users	Identify	Maintain an Inventory of Accounts	Maintain an inventory of all accounts organized by authentication system.
16.7	Users	Protect	Establish Process for Revoking Access	Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor. Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.
16.8	Users	Respond	Disable Any Unassociated Accounts	Disable any account that cannot be associated with a business process or business owner.
16.9	Users	Respond	Disable Dormant Accounts	Automatically disable dormant accounts after a set period of inactivity.
16.10	Users	Protect	Ensure All Accounts Have An Expiration Date	Ensure that all accounts have an expiration date that is monitored and enforced.
16.11	Users	Protect	Lock Workstation Sessions After Inactivity	Automatically lock workstation sessions after a standard period of inactivity.
16.12	Users	Detect	Monitor Attempts to Access Deactivated Accounts	Monitor attempts to access deactivated accounts through audit logging.
16.13	Users	Detect	Alert on Account Login Behaviour Deviation	Alert when users deviate from normal login behaviour, such as time-of-day, workstation location and duration.

CSC 16: Procedures and Tools

Although most operating systems include capabilities for logging information about account usage, these features are sometimes disabled by default. Even when such features are present and active, they often do not provide fine-grained detail about access to the system by default. Security personnel can configure systems to record more detailed information about account access, and use home-grown scripts or third-party log analysis tools to analyze this information and profile user access of various systems.

Accounts should also be tracked very closely. Any account that is dormant should be disabled and eventually removed from the system. All active accounts should be traced back to authorized users of the system and they should utilize multi-factor authentication. Users should also be logged out of the system after a period of inactivity to minimize the possibility of an attacker using their system to extract information from the organization.

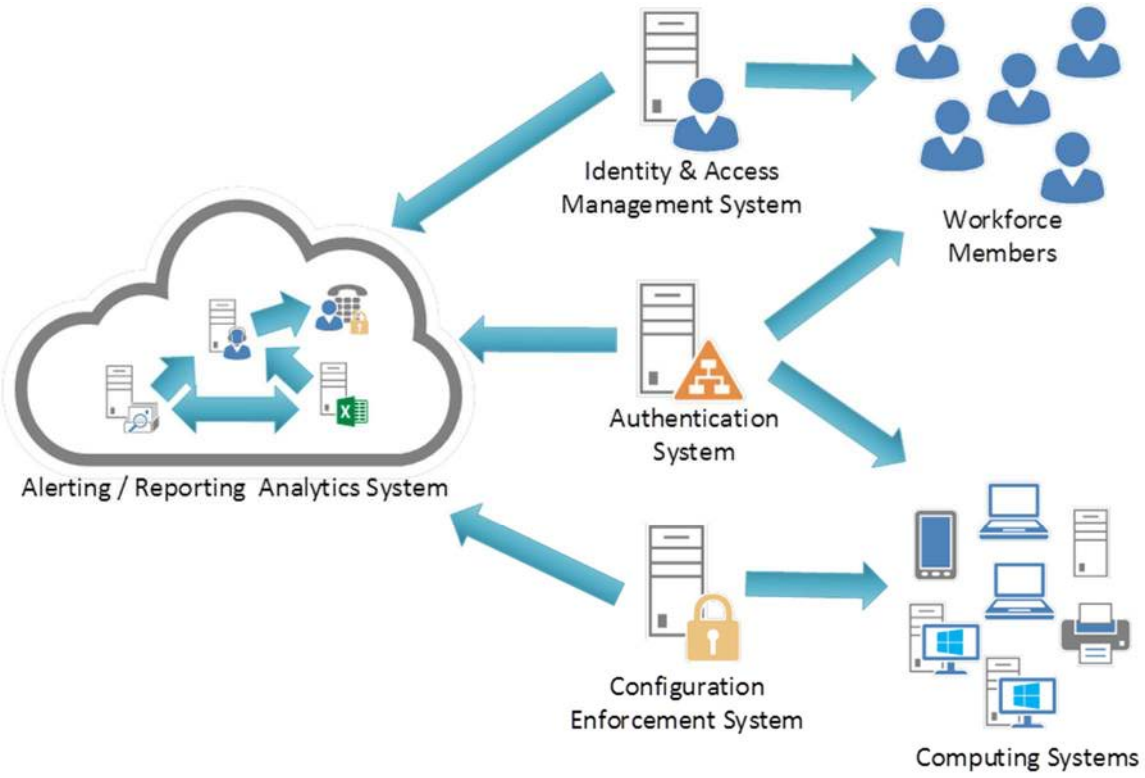


Figure 4-16: CSC 16 System Entity Relationship Diagram

4.17 CSC 17: Implement a Security Awareness and Training Program

For all functional roles in the organization (prioritizing those mission-critical to the business and its security), identify the specific knowledge, skills, and abilities needed to support defence of the enterprise; develop and execute an integrated plan to assess, identify gaps, and remediate through policy, organizational planning, training, and awareness programs.

Why Is This Control Critical?

It is tempting to think of cyber defence primarily as a technical challenge, but the actions of people also play a critical part in the success or failure of an enterprise. People fulfil important functions at every stage of system design, implementation, operation, use, and oversight. Examples include: system developers and programmers (who may not understand the opportunity to resolve root cause vulnerabilities early in the system life cycle); IT operations professionals (who may not recognize the security implications of IT artefacts and logs); end users (who may be susceptible to social engineering schemes such as phishing); security analysts (who struggle to keep up with an explosion of new information); and executives and system owners (who struggle to quantify the role that cybersecurity plays in overall operational/mission risk, and have no reasonable way to make relevant investment decisions).

Attackers are very conscious of these issues and use them to plan their exploitations by, for example: carefully crafting phishing messages that look like routine and expected traffic to an unwary user; exploiting the gaps or seams between policy and technology (e.g. policies that have no technical enforcement); working within the time window of patching or log review; using nominally non-security-critical systems as jump points or bots.

No cyber defence approach can effectively address cyber risk without a means to address this fundamental vulnerability. Conversely, empowering people with good cyber defence habits can significantly increase readiness.

Table 4-17: CSC 17 - Security Skills Assessment and Appropriate Training to Fill Gaps

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
17.1	N/A	N/A	Perform a Skills Gap Analysis	Perform a skills gap analysis to understand the skills and behaviours workforce members are not adhering to, using this information to build a baseline education roadmap.
17.2	N/A	N/A	Deliver Training to Fill the Skills Gap	Deliver training to address the skills gap identified to positively impact workforce members' security behaviour.
17.3	N/A	N/A	Implement a Security Awareness Program	Create a security awareness program for all workforce members to complete on a regular basis to ensure they understand and exhibit the necessary behaviours and skills to help ensure the security of the organization. The organization's security awareness program should be communicated in a continuous and engaging manner.
17.4	N/A	N/A	Update Awareness Content Frequently	Ensure that the organization's security awareness program is updated frequently (at least annually) to address new technologies, threats, standards and business requirements.
17.5	N/A	N/A	Train Workforce on Secure Authentication	Train workforce members on the importance of enabling and utilizing secure authentication.
17.6	N/A	N/A	Train Workforce on Identifying Social Engineering Attacks	Train the workforce on how to identify different forms of social engineering attacks, such as phishing, phone scams and impersonation calls.
17.7	N/A	N/A	Train Workforce on Sensitive Data Handling	Train workforce on how to identify and properly store, transfer, archive and destroy sensitive information.
17.8	N/A	N/A	Train Workforce on Causes of Unintentional Data Exposure	Train workforce members to be aware of causes for unintentional data exposures, such as losing their mobile devices or emailing the wrong person due to autocomplete in email.
17.9	N/A	N/A	Train Workforce Members on Identifying and Reporting Incidents	Train employees to be able to identify the most common indicators of an incident and be able to report such an incident.

CSC 17: Procedures and Resources

An effective enterprise-wide training program should take a holistic approach and consider policy and technology at the same time as the training of people. Policies should be designed with technical measurement and enforcement and they should be reinforced by training to fill gaps in understanding; technical controls can be implemented to protect systems and data and minimize the opportunity for people to make mistakes. With technical controls in place, training can be focused concepts and skills that cannot be managed technically.

An effective cyber defence training program is more than an annual event; it is an ongoing process improvement with the following key elements:

- The training is specific, tailored, and focused based on the specific behaviours and skills needed by the workforce, depending on their job role and responsibility.
- The training is repeated periodically, measured and tested for effectiveness, and updated regularly.
- It will increase awareness and discourage risky work-arounds by including rationale for good security behaviours and skills.

In the actions called out in Control 17, some critical elements of a successful training program have been identified. For more comprehensive treatment of this topic, the following resources are suggested to help the enterprise build an effective security awareness program:

- NIST SP 800-50: "Building an Information Technology Security Awareness and Training Program" [i.6].
- ENISA: "The new users' guide: How to raise information security awareness" [i.7].

- EDUCAUSE: "Cybersecurity Awareness Resource Library" [i.8].
- SANS: "Security Awareness Reports & Resource" [i.9].

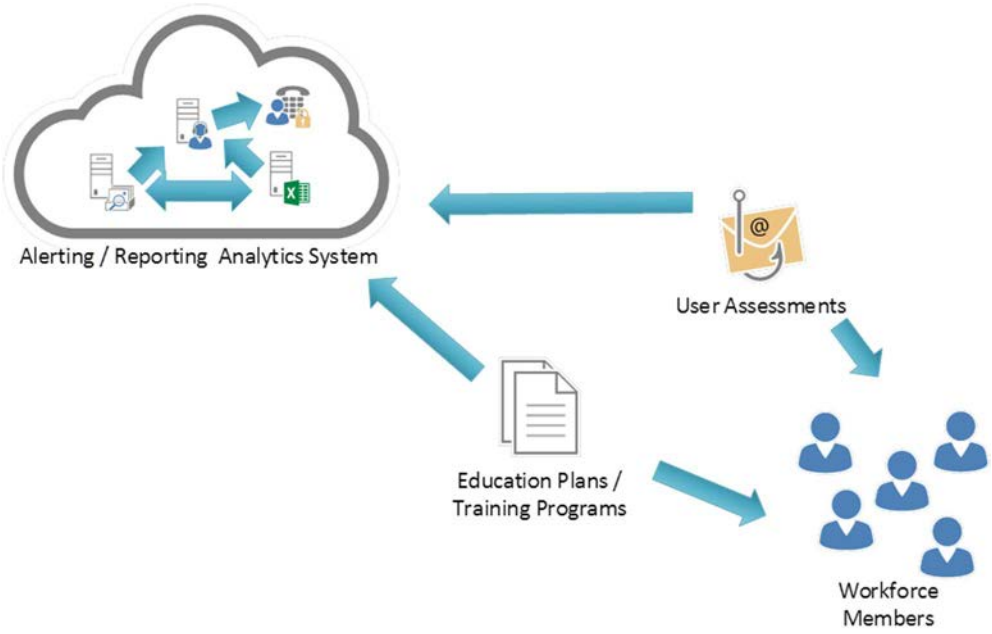


Figure 4-17: CSC 17 System Entity Relationship Diagram

4.18 CSC 18: Application Software Security

Manage the security life cycle of all in-house developed and acquired software in order to prevent, detect, and correct security weaknesses.

Why Is This Control Critical?

Attacks often take advantage of vulnerabilities found in web-based and other application software. Vulnerabilities can be present for many reasons, including coding mistakes, logic errors, incomplete requirements, and failure to test for unusual or unexpected conditions. Examples of specific errors include: the failure to check the size of user input; failure to filter out unneeded but potentially malicious character sequences from input streams; failure to initialize and clear variables; and poor memory management allowing flaws in one part of the software to affect unrelated (and more security critical) portions.

There is a flood of public and private information about such vulnerabilities available to attackers and defenders alike, as well as a robust marketplace for tools and techniques to allow "weaponization" of vulnerabilities into exploits. Attackers can inject specific exploits, including buffer overflows, SQL injection attacks, cross-site scripting, cross-site request forgery, and click-jacking of code to gain control over vulnerable machines. In one attack, more than 1 million web servers were exploited and turned into infection engines for visitors to those sites using SQL injection. During that attack, trusted websites from state governments and other organizations compromised by attackers were used to infect hundreds of thousands of browsers that accessed those websites. Many more web and non-web application vulnerabilities are discovered on a regular basis.

Table 4-18: CSC 18 - Application Software Security

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
18.1	N/A	N/A	Establish Secure Coding Practices	Establish secure coding practices appropriate to the programming language and development environment being used.
18.2	N/A	N/A	Ensure Explicit Error Checking is Performed for All In-house Developed Software	For in-house developed software, ensure that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats.
18.3	N/A	N/A	Verify That Acquired Software is Still Supported	Verify that the version of all software acquired from outside your organization is still supported by the developer or appropriately hardened based on developer security recommendations.
18.4	N/A	N/A	Only Use Up-to-date And Trusted Third-Party Components	Only use up-to-date and trusted third-party components for the software developed by the organization.
18.5	N/A	N/A	Only Standardized and Extensively Reviewed Encryption Algorithms	Use only standardized and extensively reviewed encryption algorithms.
18.6	N/A	N/A	Ensure Software Development Personnel are Trained in Secure Coding	Ensure that all software development personnel receive training in writing secure code for their specific development environment and responsibilities.
18.7	N/A	N/A	Apply Static and Dynamic Code Analysis Tools	Apply static and dynamic analysis tools to verify that secure coding practices are being adhered to for internally developed software.
18.8	N/A	N/A	Establish a Process to Accept and Address Reports of Software Vulnerabilities	Establish a process to accept and address reports of software vulnerabilities, including providing a means for external entities to contact your security group.
18.9	N/A	N/A	Separate Production and Non-Production Systems	Maintain separate environments for production and nonproduction systems. Developers should not have unmonitored access to production environments.
18.10	N/A	N/A	Deploy Web Application Firewalls	Protect web applications by deploying web application firewalls (WAFs) that inspect all traffic flowing to the web application for common web application attacks. For applications that are not web-based, specific application firewalls should be deployed if such tools are available for the given application type. If the traffic is encrypted, the device should either sit behind the encryption or be capable of decrypting the traffic prior to analysis. If neither option is appropriate, a host-based web application firewall should be deployed.
18.11	N/A	N/A	Use Standard Hardening Configuration Templates for Databases	For applications that rely on a database, use standard hardening configuration templates. All systems that are part of critical business processes should also be tested.

CSC 18: Procedures and Resources

The security of applications (in-house developed or acquired off the shelf or from external developers) is a complex activity requiring a complete program encompassing enterprise-wide policy, technology, and the role of people.

All software should be regularly tested for vulnerabilities. The operational practice of scanning for application vulnerabilities has been consolidated within Control 3: Vulnerability Assessment and Remediation. However, the most effective approach is to implement a full supply chain security program for externally acquired software and a Secure Software Development Life Cycle for internally developed software. Those aspects are addressed in this control.

For software developed in-house or customer software developed externally under contract, an effective program for applications software should address security throughout the entire life-cycle, and embed security in as a natural part of establishing requirements, training, tools, and testing. Modern development cycles and methods do not allow for sequential approaches. Acceptance criteria should always include requirements that application vulnerability testing tools be run and all known vulnerabilities be documented. It is safe to assume that software will not be perfect, and so a development program should plan up-front for bug reporting and remediation as an essential security function.

For software which is acquired (commercial, open-source, etc.), application security criteria should be part of the evaluation criteria and efforts should be made to understand the source's software practices, testing, and error reporting and management. Whenever possible, suppliers should be necessary to show evidence that standard commercial software testing tools or services were used and no known vulnerabilities are present in the current version.

The actions in Control 18 provide specific, high-priority steps that can improve Application Software Security. In addition, the following comprehensive resources dedicated to this topic are recommended:

- The Open Web Application Security Project (OWASP) is an open community that creates and shares a rich collection of software tools and documentation on application security. (https://www.owasp.org).
- Software Assurance Forum for Excellence in Code (SAFECODE) creates and encourages broad industry adoption of proven software security, integrity and authenticity practices. (https://www.safecode.org/).

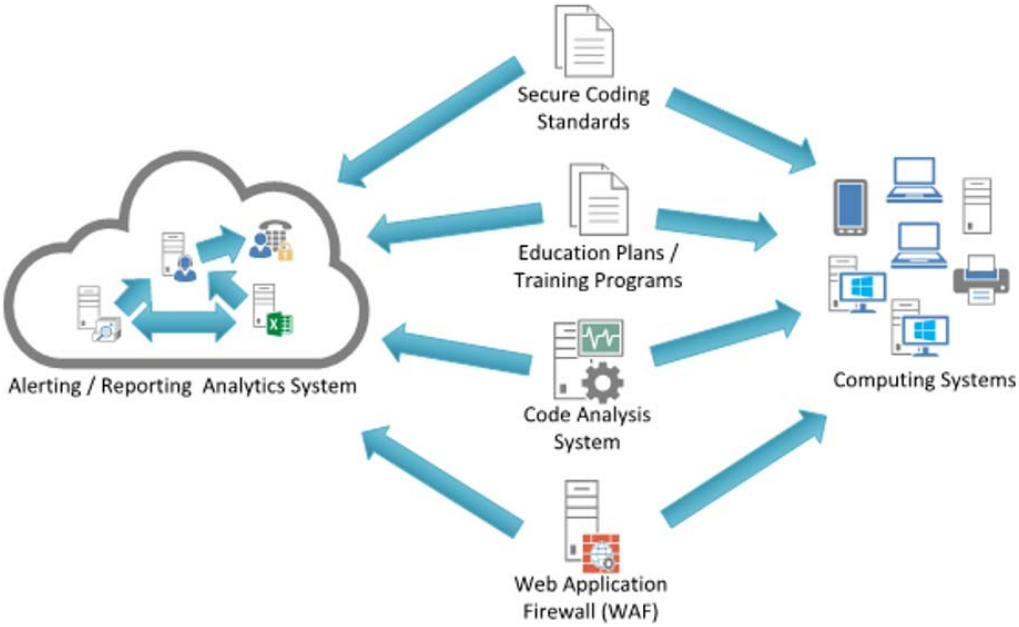


Figure 4-18: CSC 18 System Entity Relationship Diagram

4.19 CSC 19: Incident Response and Management

Protect the organization's information, as well as its reputation, by developing and implementing an incident response infrastructure (e.g. plans, defined roles, training, communications, management oversight) for quickly discovering an attack and then effectively containing the damage, eradicating the attacker's presence, and restoring the integrity of the network and systems.

Why Is This Control Critical?

Cyber incidents are now just part of our way of life. Even large, well-funded, and technically sophisticated enterprises struggle to keep up with the frequency and complexity of attacks. The question of a successful cyber-attack against an enterprise is not "if" but "when."

When an incident occurs, it is too late to develop the right procedures, reporting, data collection, management responsibility, legal protocols, and communications strategy that will allow the enterprise to successfully understand, manage, and recover. Without an incident response plan, an organization may not discover an attack in the first place, or, if the attack is detected, the organization may not follow good procedures to contain damage, eradicate the attacker's presence, and recover in a secure fashion. Thus, the attacker may have a far greater impact, causing more damage, infecting more systems, and possibly exfiltrate more sensitive data than would otherwise be possible were an effective incident response plan in place.

Table 4-19: CSC 19 - Incident Response and Management

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
19.1	N/A	N/A	Document Incident Response Procedures	Ensure that there are written incident response plans that defines roles of personnel as well as phases of incident handling/management.
19.2	N/A	N/A	Assign Job Titles and Duties for Incident Response	Assign job titles and duties for handling computer and network incidents to specific individuals and ensure tracking and documentation throughout the incident through resolution.
19.3	N/A	N/A	Designate Management Personnel to Support Incident Handling	Designate management personnel, as well as backups, who will support the incident handling process by acting in key decision-making roles.
19.4	N/A	N/A	Devise Organization-wide Standards for Reporting Incidents	Devise organization-wide standards for the time necessary for system administrators and other workforce members to report anomalous events to the incident handling team, the mechanisms for such reporting, and the kind of information that should be included in the incident notification.
19.5	N/A	N/A	Maintain Contact Information For Reporting Security Incidents	Assemble and maintain information on third-party contact information to be used to report a security incident, such as Law Enforcement, relevant government departments, vendors, and ISAC partners.
19.6	N/A	N/A	Publish Information Regarding Reporting Computer Anomalies and Incidents	Publish information for all workforce members, regarding reporting computer anomalies and incidents to the incident handling team. Such information should be included in routine employee awareness activities.
19.7	N/A	N/A	Conduct Periodic Incident Scenario Sessions for Personnel	Plan and conduct routine incident response exercises and scenarios for the workforce involved in the incident response to maintain awareness and comfort in responding to real world threats. Exercises should test communication channels, decision making, and incident responder's technical capabilities using tools and data available to them.
19.8	N/A	N/A	Create Incident Scoring and Prioritization Schema	Create incident scoring and prioritization schema based on known or potential impact to your organization. Utilize score to define frequency of status updates and escalation procedures.

CSC 19: Procedures and Tools

After defining detailed incident response procedures, the incident response team should engage in periodic scenario-based training, working through a series of attack scenarios fine-tuned to the threats and vulnerabilities the organization faces. These scenarios help ensure that team members understand their role on the incident response team and also help prepare them to handle incidents. It is inevitable that exercise and training scenarios will identify gaps in plans and processes, and unexpected dependencies.

The actions in Control 18 provide specific, high-priority steps that can improve enterprise security, and should be a part of any comprehensive incident and response plan. In addition, the following resources dedicated to this topic may be useful.

- ETSI TR 103 331: "CYBER; Structured threat information sharing" [i.10].

- OASIS Common Security Advisory Framework (CSAF) Technical Committee Common Vulnerability Reporting Framework (CVRF).

NOTE 1: https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=csaf.

- CREST Cyber Security Incident Response Guide [i.11].

NOTE 2: https://www.crest-approved.org/wp-content/uploads/2014/11/CSIR-Procurement-Guide.pdf.

- CREST provides guidance, standards, and knowledge on a wide variety of cyber defence topics [i.12].

NOTE 3: https://www.crest-approved.org/wp-content/uploads/2014/11/CSIR-Procurement-Guide.pdf.

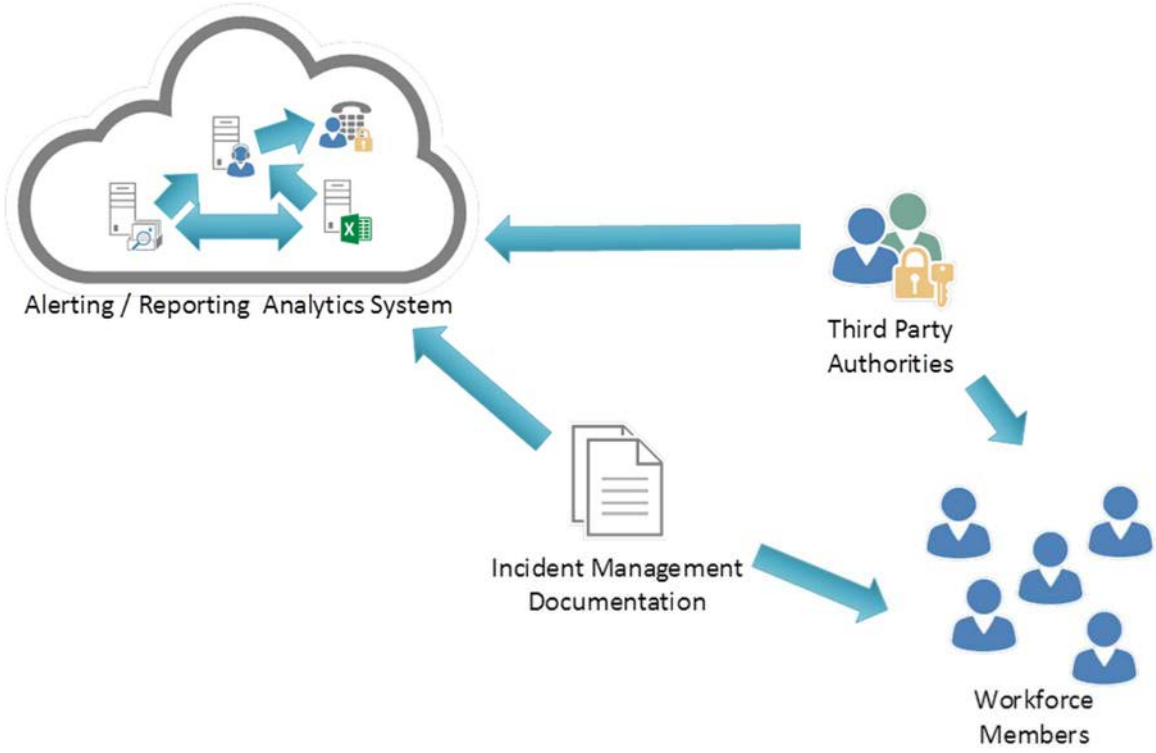


Figure 4-19: CSC 19 System Entity Relationship Diagram

4.20 CSC 20: Penetration Tests and Red Team Exercises

Test the overall strength of an organization's defences (the technology, the processes, and the people) by simulating the objectives and actions of an attacker.

Why Is This Control Critical?

Attackers often exploit the gap between good defensive designs and intentions and implementation or maintenance. Examples include: the time window between announcement of a vulnerability, the availability of a vendor patch, and actual installation on every machine. Other examples include: well-intentioned policies that have no enforcement mechanism (especially those intended to restrict risky human actions); failure to apply good configurations to machines that come on and off the network; and failure to understand the interaction among multiple defensive tools, or with normal system operations that have security implications.

A successful defensive posture requires a comprehensive program of effective policies and governance, strong technical defences, and appropriate action by people. In a complex environment where technology is constantly evolving, and new attacker tradecraft appears regularly, organizations should periodically test their defences to identify gaps and to assess their readiness by conducting penetration testing.

Penetration testing starts with the identification and assessment of vulnerabilities that can be identified in the enterprise. Next, tests are designed and executed to demonstrate specifically how an adversary can either subvert the organization's security goals (e.g. the protection of specific Intellectual Property) or achieve specific adversarial objectives (e.g. establishment of a covert Command and Control infrastructure). The results provide deeper insight, through demonstration, into the business risks of various vulnerabilities.

Red Team exercises take a comprehensive approach at the full spectrum of organization policies, processes, and defences in order to improve organizational readiness, improve training for defensive practitioners, and inspect current performance levels. Independent Red Teams can provide valuable and objective insights about the existence of vulnerabilities and the efficacy of defences and mitigating controls already in place and even of those planned for future implementation.

Table 4-20: CSC 20 - Penetration Tests and Red Team Exercises

Sub-Control	Asset Type	Security Function	Control Title	Control Descriptions
20.1	N/A	N/A	Establish a Penetration Testing Program	Establish a program for penetration tests that includes a full scope of blended attacks, such as wireless, client-based, and web application attacks.
20.2	N/A	N/A	Conduct Regular External and Internal Penetration Tests	Conduct regular external and internal penetration tests to identify vulnerabilities and attack vectors that can be used to exploit enterprise systems successfully.
20.3	N/A	N/A	Perform Periodic Red Team Exercises	Perform periodic Red Team exercises to test organizational readiness to identify and stop attacks or to respond quickly and effectively.
20.4	N/A	N/A	Include Tests for Presence of Unprotected System Information and Artefacts	Include tests for the presence of unprotected system information and artefacts that would be useful to attackers, including network diagrams, configuration files, older penetration test reports, emails or documents containing passwords or other information critical to system operation.
20.5	N/A	N/A	Create a Test Bed for Elements Not Typically Tested in Production	Create a test bed that mimics a production environment for specific penetration tests and Red Team attacks against elements that are not typically tested in production, such as attacks against supervisory control and data acquisition and other control systems.
20.6	N/A	N/A	Use Vulnerability Scanning and Penetration Testing Tools in Concert	Use vulnerability scanning and penetration testing tools in concert. The results of vulnerability scanning assessments should be used as a starting point to guide and focus penetration testing efforts.
20.7	N/A	N/A	Ensure Results from Penetration Test are Documented Using Open, Machine-readable Standards	Wherever possible, ensure that Red Teams results are documented using open, machine-readable standards (e.g. SCAP). Devise a scoring method for determining the results of Red Team exercises so that results can be compared over time.
20.8	N/A	N/A	Control and Monitor Accounts Associated with Penetration Testing	Any user or system accounts used to perform penetration testing should be controlled and monitored to make sure they are only being used for legitimate purposes, and are removed or restored to normal function after testing is over.

CSC 20: Procedures and Resources

Historically, penetration tests and Red Team Tests are performed for specific purposes:

- as a "dramatic" demonstration of an attack, usually to convince decision-makers of their enterprise's vulnerability;
- as a means to test the correct operation of enterprise defences ("verification"); and
- to test that the enterprises has built the right defences in the first place ("validation").

In general, these kinds of tests are expensive, complex, and potentially introduce their own risks. They can provide significant value, but only when basic defensive measures are already in place, and when these tests are performed as part of a comprehensive, ongoing program of security management and improvement. Test events are a very expensive way to discover that your enterprise does a poor job with patching and configuration management, for example.

Each organization should define a clear scope and rules of engagement for penetration testing and Red Team analyses. The scope of such projects should include, at a minimum, systems with the organization's highest value information and production processing functionality. Other lower-value systems may also be tested to see if they can be used as pivot points to compromise higher-value targets. The rules of engagement for penetration tests and Red Team analyses should describe, at a minimum, times of day for testing, duration of tests, and the overall test approach.

The actions in CIS Control 20 provide specific, high-priority steps that can improve enterprise security, and should be a part of any penetration testing and Red Team program. In addition, use is recommended of some of the excellent comprehensive resources dedicated to this topic to support security test planning, management, and reporting:

- OWASP Penetration Testing Methodologies [i.14].

NOTE 1: Available at https://www.owasp.org/index.php/Penetration_testing_methodologies.

- PCI Security Standards Council [i.13].

NOTE 2: Available at https://www.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf.

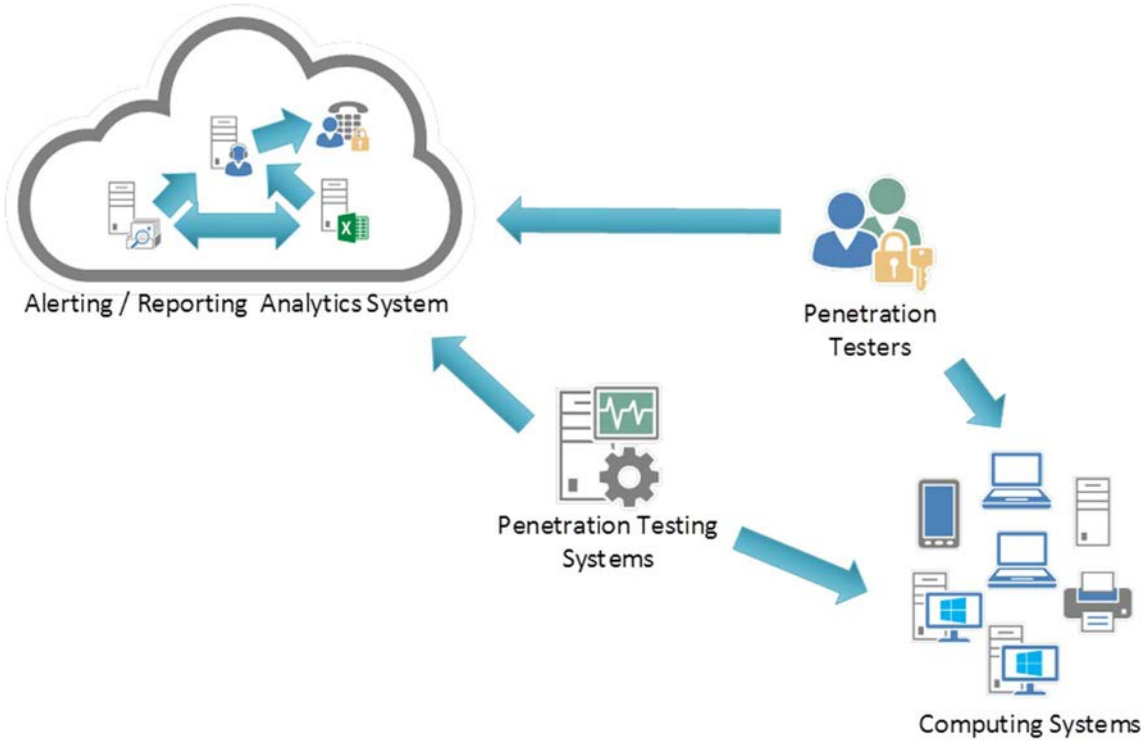


Figure 4-20: CSC 20 System Entity Relationship Diagram

History

Document history		
V1.1.1	May 2015	Publication as ETSI TR 103 305
V2.1.1	August 2016	Publication
V3.1.1	September 2018	Publication